

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỖI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

Giảng viên hướng dẫn:

TS. Bùi Văn Hiệu

TS. Đặng Văn Hiếu

Tóm tắt

Trung tâm Điều hành An ninh được đánh giá ở chỗ một cuộc xâm nhập thật có bị bắt kịp lúc hay không, thế nhưng khối lượng hoạt động phải soi xét lại vượt xa những gì các chuyên viên trực ca đọc nổi. Các hướng đối phó hiện hành mỗi hướng chỉ giải quyết được một phần: luật chữ ký quyết định rất nhanh nhưng không diễn giải được ý đồ, nền tảng tương quan gom được bằng chứng nhưng vẫn trao cho con người nhiều ứng viên hơn mức họ xử lý xuể, còn kịch bản tự động chỉ chạy đáng tin trên đúng những tình huống đã có người lường trước. Phần động lại cho chuyên viên—dựng ngữ cảnh quanh một cảnh báo rồi phán đoán nó—đúng là phần không mở rộng quy mô được. Luận văn đề xuất SENTINEL, một kiến trúc an ninh nhận thức hai tầng vận hành cục bộ hoàn toàn (air-gapped), đặt quyết định rẽ đúng trước quyết định đắt để năng lực suy luận chỉ tiêu tốn ở nơi thật sự cần. Tầng 1 là bộ lọc tốc độ đường truyền—luật xác định, chấm bắt thường Welford và cổng LightGBM—giải quyết nhiều nền của luồng mà không phải gọi tới mô hình ngôn ngữ. Sự kiện sống sót mới tới Tầng 2, một tác tử suy luận có trạng thái vận hành mô hình lượng tử hoá đặt tại chỗ, phía sau các rào chắn mật mã. Ngữ cảnh của nó được dựng từ chính sự kiện (dòng yêu cầu, tiêu đề, payload, thống kê luồng), nén lại bằng kỹ thuật gom khuôn mẫu nhật ký dưới một ngân sách token tường minh; tri thức an ninh được biểu diễn thành kho truy xuất gồm 433 mục MITRE ATT&CK và 107 quy trình NIST SP 800-61r2, lập chỉ mục vừa dạng véc-tơ dày cho tương đồng ngữ nghĩa vừa dạng chỉ mục thưa BM25 cho các định danh chính xác, hai bảng hạng hợp nhất bằng Hợp nhất Hạng Nghịch đảo. Một phép kiểm ở đầu ra buộc mọi kỹ thuật mà tác tử khẳng định phải có mặt trong tập tài liệu truy xuất của chính lô đó, nếu không phán quyết được giữ lại chờ chuyên viên. Kết quả thực nghiệm trên các bộ dữ liệu xâm nhập chuẩn cho thấy hiệu quả của SENTINEL. Tầng 1 cùng Cổng Học máy tự động gỡ tải **90,6%** lưu lượng đầu vào. Vì sự kiện điển hình không bao giờ chạm tới mô hình, độ trễ toàn tuyến ở mức trung vị giảm còn **0,88 ms** so với **17.174,7 ms** của đường LLM đơn tầng. Cơ chế đóng gói Nonce vô hiệu hoá tiêm nhiễm câu lệnh bằng cấu trúc chứ không bằng nhận dạng nội dung, kháng được toàn bộ **678** mẫu đối kháng mà lớp lọc tĩnh không hấp thụ được; chuỗi niêm phong HMAC-SHA256 phát hiện mọi kiểu giả mạo cốt lõi, qua

đó bảo đảm tính toàn vẹn và khả năng phát hiện giả mạo của nhật ký kiểm toán—song do dùng khoá đối xứng, không cấu thành chống chối bỏ theo nghĩa mật mã học—toàn bộ vận hành trên một máy trạm local. SENTINEL chứng minh kiến trúc lai hai tầng là một mô hình phòng thủ đáng tin cậy và hiệu quả cho SOC hiện đại.

Lời cảm ơn

Để hoàn thành công trình nghiên cứu này và đạt được học vị Thạc sĩ Kỹ thuật Phần mềm, tôi đã nhận được sự hỗ trợ, động viên và dìu dắt quý báu từ rất nhiều cá nhân và tập thể.

Trước hết, tôi xin bày tỏ lòng biết ơn chân thành và kính trọng sâu sắc nhất tới hai thầy hướng dẫn khoa học của tôi, TS. Bùi Văn Hiệu và TS. Đặng Văn Hiếu. Với tri thức học thuật uyên bác, sự định hướng chiến lược chuẩn xác và tinh thần làm việc nghiêm túc, quý thầy đã luôn dành thời gian kiên nhẫn chỉ bảo, định hướng tư duy phản biện và truyền cảm hứng nghiên cứu cho tôi trong suốt chặng đường thực hiện luận văn. Những góp ý chuyên môn sắc bén của quý thầy không chỉ giúp tôi hoàn thiện công trình này mà còn là hành trang tri thức vô giá cho sự nghiệp nghiên cứu an toàn thông tin và trí tuệ nhân tạo của tôi sau này.

Tôi xin trân trọng gửi lời tri ân tới Ban Giám hiệu, Ban Lãnh đạo Viện Quản trị & Công nghệ FSB cùng toàn thể quý thầy cô Trường Đại học FPT đã truyền dạy nền tảng tri thức lý thuyết và thực tiễn vững chắc trong một môi trường nghiên cứu chuyên nghiệp, hiện đại. Tôi cũng xin chân thành cảm ơn Ban Lãnh đạo cùng các đồng nghiệp tại Cục C12, Trung tâm Dữ liệu Quốc gia—sự tin tưởng, điều kiện thuận lợi về thời gian cùng những kinh nghiệm thực chiến phong phú từ đơn vị đã đem lại góc nhìn thực tiễn sâu sắc, áp dụng trực tiếp vào quá trình thiết kế, thực nghiệm và kiểm chứng hệ thống SENTINEL.

Cuối cùng, và cũng là niềm tự hào lớn lao nhất, tôi xin dành trọn lòng tri ân sâu sắc nhất tới gia đình thân yêu, đặc biệt là người vợ hiền cùng con nhỏ. Sự hy sinh thầm lặng, lòng kiên nhẫn vô bờ bến và nguồn động viên không ngừng nghỉ của vợ và con trong những tháng ngày tôi miệt mài với các đợt thực nghiệm kéo dài xuyên đêm chính là điểm tựa vững chắc nhất giúp tôi hoàn thành công trình này. Mặc dù đã rất cố gắng, luận văn khó tránh khỏi hạn chế; tôi rất mong nhận được sự chỉ dẫn và đóng góp quý báu từ quý thầy cô trong Hội đồng chấm luận văn cùng các đồng nghiệp.

Mục lục

Tóm tắt	i
Lời cảm ơn	iii
Danh sách hình vẽ	v
Danh sách bảng	v
Danh mục các từ viết tắt	vii
1 Giới thiệu	1
1.1 Bối cảnh và Động lực Nghiên cứu	1
1.2 Mục tiêu, Câu hỏi Nghiên cứu, Phạm vi và Đóng góp	3
1.3 Cấu trúc của Luận văn	5
2 Cơ sở Lý thuyết và Tổng quan Nghiên cứu	6
2.1 Thực trạng Vận hành SOC và Nút thắt Nhận thức	6
2.2 Lý thuyết Thống kê Trực tuyến và Học máy Tầng 1	6
2.3 Mô hình Ngôn ngữ Lớn Cục bộ và Trí tuệ Tác tử Tầng 2	7
2.4 An ninh Đối kháng AI và Mật mã học Kiểm toán Nhật ký	8
2.5 Tổng quan Nghiên cứu Liên quan và Khoảng trống Nghiên cứu	9
3 Thiết kế Hệ thống và Triển khai Kỹ thuật	11
3.1 Phương pháp Nghiên cứu	11
3.2 Kiến trúc Tổng thể SENTINEL và Tích hợp Ngăn xếp SOC	12
3.3 Tầng 1: Bộ lọc Tốc độ Đường truyền và Cổng Học máy	13
3.4 Tầng 2: Tác tử Nhận thức LangGraph và Bộ nhớ Đề dọa	15
3.5 Cơ chế Truy xuất Tri thức Lai Dual-RAG	17
3.6 Kiến trúc An ninh AI và Niêm phong Kiểm toán Mật mã	18
3.7 SOC Dashboard và Kiến trúc Triển khai Cục bộ	20
4 Thực nghiệm và Đánh giá	22
4.1 Môi trường Thực nghiệm và Giao ước Đo lường	22
4.2 RQ1 — Xả tải và Kinh tế học Tầng lọc	24
4.3 RQ2 — Rào chắn An ninh AI và Toàn vẹn Pháp y	28
4.4 RQ3 — Suy luận Có trạng thái và Quy kết Kỹ thuật	34
5 Kết luận	41
Tài liệu tham khảo	1

Danh sách hình vẽ

Hình 1.	SENTINEL ở mức khối: hai tầng tách nhau theo chi phí, với một đường leo thang duy nhất nối giữa. (Nguồn: Tác giả)	12
Hình 2.	Tầng 1 phóng to. Chỉ nhánh ESCALATE đi tới Tầng 2; mọi phán quyết khác kết thúc tại đây, và đó chính là thứ Chương 4 tính là xả tải. (Nguồn: Tác giả)	14
Hình 3.	Đồ thị trạng thái tác tử Tầng 2, phản ánh đúng <code>src/agent/workflow.py</code> : đồ thị không chu trình, mọi đường đi đều kết thúc ở một hành động đã thực thi, một lần chuyển chuyên viên, hoặc kết thúc chu kỳ. (Nguồn: Tác giả)	16
Hình 4.	Truy xuất Dual-RAG và rào chắn neo bằng chứng. Phép kiểm nằm ở phía đầu ra: nó ràng buộc thứ mô hình được phép khẳng định, không phải thứ bộ truy xuất được phép trả về. (Nguồn: Tác giả)	18
Hình 5.	Đóng gói nonce ở biên đầu vào và chuỗi HMAC ở biên đầu ra. Điểm mù cắt đuôi được vẽ ra chứ không lược đi, vì nó là hệ quả của chính cấu trúc. (Nguồn: Tác giả)	20
Hình 6.	Cơ cấu xả tải trên hai luồng. Tầng gánh chính đảo vai theo tỉ lệ tấn công nền. Sinh từ <code>offload_vs_baserate_{stream,demo}.json</code> . (Nguồn: Tác giả)	25
Hình 7.	Phân phối tích lũy độ trễ trên cùng 500 sự kiện. Lợi thế tập trung ở thân phân phối; ở phần đuôi thì hệ hai tầng chậm hơn. Sinh từ <code>latency_benchmark.json</code> . (Nguồn: Tác giả)	27
Hình 8.	Lớp lọc tĩnh: tỉ lệ chặn theo xuất xứ đặt cạnh tỉ lệ báo nhằm trên log lạnh. Sinh từ <code>robustness_results.json</code> và <code>adversarial_negative_results.json</code> . (Nguồn: Tác giả)	30
Hình 9.	Quy kết theo từng kỹ thuật đặt cạnh trần truy xuất. Chỗ nào cột nhạt cao mà hai cột đậm bằng không thì lỗi ở bộ ánh xạ; chỗ nào cột nhạt bằng không thì lỗi ở kho tri thức. Sinh từ ba tệp kết quả RQ3. (Nguồn: Tác giả)	35
Hình 10.	Phân loại cảnh báo ở Tầng 2. Kênh khẳng định gần như toàn báo giả; kênh hoãn mới là nơi đe dọa thật dồn về. Sinh từ <code>tier2_decision_results.json</code> . (Nguồn: Tác giả)	37

Danh sách bảng

Bảng 1.	Bảng so sánh đối chiếu giữa SENTINEL và các giải pháp phòng thủ hiện hành	10
Bảng 2.	Cấu hình Thực nghiệm và Phân vai Tập Dữ liệu	23
Bảng 3.	Tỉ lệ Xả tải theo Từng Tầng trên Hai Luồng có Base-rate Khác nhau	24
Bảng 4.	Thông lượng các cấu hình đối chứng trên cùng mẫu con 150 sự kiện phân tầng	27
Bảng 5.	Các lớp rào chắn, mẫu số phép đo và kết quả	30
Bảng 6.	Quy kết theo từng kỹ thuật trên lát 500 mẫu tầng payload, kèm trần truy xuất của cùng bộ truy vấn. Quy kết chấm trên cả 250 mẫu có nhãn; truy xuất chấm trên 243 mẫu mà Tầng 1 có leo thang, và ở mức kỹ thuật cha—hai mẫu số vì vậy lệch nhau đôi chút và không thay thế cho nhau được.	35
Bảng 7.	Bóc tách thành phần chấm theo hành động cuối, đã loại 50 mẫu tác giả tự soạn. Cấu hình A và F chấm trên toàn bộ 1.700 mẫu còn lại; B–E chấm trên một lát 300 mẫu riêng nên không so trực tiếp với A và F được. Sinh từ <code>ablation_action_scores.json</code>	39

Danh mục các từ viết tắt

Từ viết tắt	Định nghĩa đầy đủ
AI	Artificial Intelligence (Trí tuệ nhân tạo)
APT	Advanced Persistent Threat (Mối đe dọa thường trực nâng cao)
CTI	Cyber Threat Intelligence (Tình báo mối đe dọa mạng)
DAPT	Dynamic Advanced Persistent Threat (Tấn công APT động)
FAISS	Facebook AI Similarity Search (Cơ máy tìm kiếm tương đồng FAISS)
FPR	False Positive Rate (Tỷ lệ báo động giả)
GGUF	GPT-Generated Unified Format (Định dạng hợp nhất GGUF)
HITL	Human-in-the-Loop (Con người trong vòng lặp)
HMAC	Hash-based Message Authentication Code (Mã xác thực thông điệp dựa trên hàm băm)
LLM	Large Language Model (Mô hình ngôn ngữ lớn)
MITRE ATT&CK	MITRE Adversarial Tactics, Techniques, and Common Knowledge (Khung tri thức chiến thuật và kỹ thuật tấn công MITRE)
NIST	National Institute of Standards and Technology (Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ)
RAG	Retrieval-Augmented Generation (Sinh văn bản tăng cường truy xuất)
RRF	Reciprocal Rank Fusion (Tổng hợp xếp hạng nghịch đảo)
SIEM	Security Information and Event Management (Quản lý thông tin và sự kiện an ninh)
SOAR	Security Orchestration, Automation, and Response (Điều phối, tự động hóa và phản hồi an ninh)
SOC	Security Operations Center (Trung tâm điều hành an ninh mạng)

Chương 1

Giới thiệu

Chương này xác lập bối cảnh nghiên cứu và bài toán trung tâm của SENTINEL—một kiến trúc nhận thức hai tầng tự động hoá quy trình phát hiện và phản hồi sự cố trong các Trung tâm Điều hành An ninh (SOC)—đồng thời phát biểu mục tiêu, câu hỏi nghiên cứu, phạm vi và đóng góp của luận văn.

1.1 Bối cảnh và Động lực Nghiên cứu

Các cuộc tấn công mạng ngày càng gia tăng cả về số lượng lẫn mức độ tinh vi, và gánh nặng phòng thủ mà chúng đặt ra cũng tăng theo. Một Trung tâm Điều hành An ninh cỡ vừa hiện mỗi ngày nhận về hàng triệu sự kiện nhật ký [1], trong đó phần áp đảo chỉ ghi lại hoạt động bình thường. Vì cái giá của việc bỏ lọt một cuộc xâm nhập lớn hơn nhiều so với cái giá của việc xem xét một sự kiện vô hại, các hệ thống giám sát được đặt lệch hẳn về phía nhạy, và tỉ lệ báo động giả do đó vượt quá 80% [2]. Sự bất đối xứng này còn cộng dồn: mỗi cảm biến lắp thêm đều làm số cảnh báo tăng lên, trong khi số chuyên viên đủ sức đọc những cảnh báo ấy vẫn giữ nguyên. Chỗ nghẽn của một SOC hiện đại vì vậy không nằm ở khả năng phát hiện. Nó nằm ở việc phân bổ sự chú ý khan hiếm của con người—thứ không nhân lên được bằng cách mua thêm máy chủ.

Trước áp lực đó, giới phòng thủ hiện dựa vào ba lớp đối phó. Ở vành ngoài, tường lửa và hệ thống phát hiện xâm nhập đối sánh lưu lượng với chữ ký tĩnh và luật tắt định, chặn những gì đã được mô tả từ trước. Phía sau, nền tảng SIEM gom telemetry từ toàn bộ hạ tầng về một chỗ và tương quan chúng bằng các luật do đội an ninh viết. Trên cả hai, nền tảng SOAR thực thi kịch bản lập trình sẵn để một tình huống đã nhận dạng được sẽ kích hoạt phản ứng

theo kịch bản mà không phải chờ người [3]. Mọi thứ ba lớp này không kết luận được đều rơi vào hàng đợi của chuyên viên, và ở đó công việc trở thành thủ công: chuyên viên lấy nhật ký thô ra, dừng lại xem địa chỉ nguồn đã làm gì trước và sau thời điểm bị gấn cờ, đối chiếu địa chỉ đích với danh mục tài sản nội bộ, tra xem hành vi ấy giống kỹ thuật tấn công nào, rồi mới quyết định chặn, bỏ qua hay chuyển tiếp. Mỗi bước trong đó đều là đọc và đối chiếu, mà đọc thì không song song hoá được.

Hai nhược điểm nảy sinh trực tiếp từ đây, và chúng chính là lý do tồn tại của luận văn này. Thứ nhất là **thời gian**. Chuyên viên cần vài phút để xử lý một cảnh báo trong khi luồng dữ liệu đến liên tục, nên bất kỳ hàng đợi nào có tốc độ đến vượt tốc độ phục vụ đều phình ra vô hạn—và tồn đọng được giải quyết không phải bằng cách làm xong mà bằng cách bỏ dở. Thứ hai là **ngữ cảnh**. Bằng chứng quyết định một vụ việc thường nằm rải rác trên nhiều bản ghi tách rời và vùi trong những trường văn bản dài, phi cấu trúc, nên phán quyết đòi hỏi phải giữ trong đầu cùng lúc một khối ngữ cảnh dài và không đồng nhất. Luật tính hoàn toàn không diễn đạt nổi điều đó, bởi thứ cần đến không phải một khuôn mẫu để đối sánh mà là một phán đoán phải hình thành. Đây chính là lý do các công cụ tự động hoá hiện hành không gỡ được gánh nặng: chữ ký và kịch bản chỉ nhận ra những gì đã được mô tả, chúng thất bại trước biến thể nằm ngoài mô tả, và tuy phân loại được sự kiện, chúng không giải thích được vì sao sự kiện ấy đáng quan tâm. Mô hình Ngôn ngữ Lớn hứa hẹn đúng năng lực còn thiếu ấy—đọc một sự kiện trong ngữ cảnh của nó và diễn giải bằng thứ ngôn ngữ con người hành động được—nhưng đưa một mô hình như vậy vào thẳng luồng dữ liệu vận hành lại sinh ra ba khoản chi phí mới. Mỗi lần suy luận mất vài giây trong khi dữ liệu vẫn đến [4]. Bản thân tầng suy luận trở thành mục tiêu, bởi một trường nhật ký có thể mang theo câu chữ do kẻ tấn công cố ý soạn để lái mô hình [5], và những gì mô hình kết luận thì phải chứng minh được là chưa bị sửa đổi nếu muốn dùng làm chứng cứ. Và nhật ký nội bộ thường không được phép rời khỏi tổ chức, nên mô hình phải chạy tại chỗ, trên phần cứng hữu hạn [6].

Quan sát nền tảng của nghiên cứu này là chênh lệch chi phí giữa hai loại phán quyết. Một phán quyết bằng luật thống kê tốn chưa tới một phần nghìn giây; một phán quyết bằng mô hình ngôn ngữ tốn hàng giây. Khoảng cách bốn đến năm bậc độ lớn ấy khiến việc đem mọi

sự kiện qua tầng đất nhất trở thành lãng phí có hệ thống, trong khi tuyệt đại đa số sự kiện vốn có thể kết luận bằng những phép kiểm rất rẻ. Mục tiêu của luận văn vì vậy là thiết kế, xây dựng và đánh giá thực nghiệm **SENTINEL**, một kiến trúc hai tầng dựng trên nguyên lý *đặt phán quyết rẻ trước phán quyết đắt*: một tầng lọc nhanh giải quyết dứt điểm phần lớn lưu lượng, và một tầng suy luận chỉ được gọi tới cho phần còn lại, vận hành phía sau các rào chắn bảo vệ cùng một vết kiểm toán niêm phong bằng mật mã, hoàn toàn trên hạ tầng cục bộ. Điều khiến đây là bài toán nghiên cứu chứ không chỉ là bài toán kỹ thuật nằm ở chỗ cả ba khoản chi phí trên đều phải *đo được*, trên dữ liệu thật, bằng những thước đo không tự tăng bốc.

1.2 Mục tiêu, Câu hỏi Nghiên cứu, Phạm vi và Đóng góp

Mục tiêu tổng quát được cụ thể hoá thành ba nhiệm vụ nghiên cứu. Mỗi nhiệm vụ đặt tương ứng một-một với một câu hỏi nghiên cứu và với đóng góp mà nó hướng tới, và Chương 4 báo cáo kết quả theo đúng ba đề mục ấy, để mục tiêu, câu hỏi và bằng chứng luôn khớp nhau xuyên suốt.

Thứ nhất — kinh tế học tầng lọc. Mục tiêu là xây dựng đường ống lọc hai chặng phi trạng thái vận hành ở tốc độ đường truyền, sao cho phần lớn telemetry được giải quyết ngay tại tầng rẻ mà không tiêu tốn tài nguyên GPU. Câu hỏi tương ứng, **RQ1**, đặt vấn đề: *Làm thế nào để thiết kế một kiến trúc phân tầng có khả năng xả tải tự động luồng dữ liệu an ninh ở tốc độ đường truyền nhằm giải quyết vấn đề “nút thắt cổ chai” về độ trễ và tiêu thụ tài nguyên của các Mô hình Ngôn ngữ Lớn?* Đóng góp hướng tới là đề xuất và định lượng nguyên lý đặt phán quyết rẻ trước phán quyết đắt, đồng thời chứng minh bằng số đo rằng tỉ lệ xả tải là **hàm của tỉ lệ tấn công nền trong luồng** chứ không phải hằng số của hệ—đặc tính chưa được các công trình liên quan phát biểu tường minh.

Thứ hai — an ninh của tầng suy luận. Mục tiêu là bảo vệ mô hình ngôn ngữ bằng cấu trúc thay vì bằng xác suất, và niêm phong hồ sơ pháp y sao cho mọi sửa đổi đều phát hiện được. Câu hỏi tương ứng, **RQ2**, đặt vấn đề: *Phương pháp luận và cơ chế bảo mật nào có khả năng chống lại các rủi ro đối kháng (điển hình như tiêm nhiễm prompt qua nhật ký)*

nhằm bảo vệ luồng suy luận của AI, đồng thời bảo đảm tính toàn vẹn và khả năng phát hiện giả mạo của các vết chứng cứ pháp y? Đóng góp hướng tới là cơ chế phòng thủ dựa trên Đóng gói Dữ liệu Phân định với Nonce mật mã ngẫu nhiên, mà tính chất cốt lõi là nó **không phụ thuộc vào tỉ lệ chặn của bất kỳ bộ phân loại nào**: nội dung trong vùng bọc được xử lý như văn bản thụ động bất kể nó nói gì, khác hẳn các bộ lọc ngữ nghĩa xác suất vốn suy giảm trước biến thể mới [7].

Thứ ba — suy luận, quy kết và tải người. Mục tiêu là một cỗ máy suy luận có trạng thái biết truy xuất tri thức chuyên ngành, trích dẫn bằng chứng đã dùng, và chuyển cho con người đúng những ca xứng đáng. Câu hỏi tương ứng, **RQ3**, đặt vấn đề: *Làm thế nào để tích hợp năng lực suy luận có trạng thái và khả năng tra cứu tri thức chuyên ngành vào Tác tử AI nhằm tự động hóa quy trình phân tích, quy kết kỹ thuật tấn công và sinh ra các báo cáo pháp y minh bạch, qua đó giảm tải và phân loại chính xác phần công việc cần đến chuyên gia?* Đóng góp hướng tới là thay kịch bản SOAR cứng nhắc bằng một tác tử có trạng thái trên kho tri thức MITRE ATT&CK chuẩn STIX, kèm rào chắn neo-RAG tắt định buộc mọi mã kỹ thuật công bố phải hiện diện trong tài liệu truy xuất của chính lô đó—biến việc chống hư cấu từ một kỳ vọng đặt vào mô hình thành một ràng buộc kiểm chứng được của kiến trúc.

Phạm vi. Đối tượng nghiên cứu là chính kiến trúc SENTINEL: bộ lọc phi trạng thái Tầng 1, bộ đệm ngữ nghĩa Tầng 1.75, cỗ máy tác tử có trạng thái Tầng 2 chạy mô hình lượng tử hoá lưu trữ cục bộ, hệ truy xuất lai trên tri thức MITRE ATT&CK, cùng các cơ chế mật mã bảo vệ cả hai. Đánh giá thực nghiệm dựa trên **hai tập dữ liệu chính**—CSE-CIC-IDS2018 [8] cho luồng giám sát mạng diện rộng và CSIC 2010 [9] cho tấn công HTTP Tầng 7 thực tế. Hai nguồn bổ trợ là DAPT2020 [10] cho chuỗi xâm nhập đa giai đoạn và một tập zero-day tổng hợp chỉ đóng vai trò **minh chứng khả thi**, không tham gia bất kỳ tuyên bố đóng góp nào. Đánh giá đối kháng dùng 823 mẫu tách theo xuất xứ và không bao giờ gộp: **703 mẫu từ nguồn công bố** (AdvBench [11], deepset [12], jackhhao [13]) làm mẫu số chính, 80 mẫu tác giả biên soạn, và 40 mẫu kiểm chéo. Hệ thống triển khai trên một máy trạm cục bộ vận hành hoàn toàn cách ly mạng, và danh mục hành động tự động giới hạn ở chặn địa chỉ IP, ghi nhật ký hoặc chuyển chuyên gia; can thiệp hạ tầng vật lý nằm ngoài phạm vi.

1.3 Cấu trúc của Luận văn

Chương 2 hệ thống hoá cơ sở lý thuyết và tổng quan công trình liên quan nhằm xác định khoảng trống nghiên cứu. Chương 3 trình bày phương pháp nghiên cứu và thiết kế kỹ thuật của SENTINEL. Chương 4 trình bày kết quả định lượng, tổ chức theo đúng ba câu hỏi nghiên cứu ở trên. Chương 5 kết luận.

Chương 2

Cơ sở Lý thuyết và Tổng quan Nghiên cứu

Chương này trình bày cơ sở lý thuyết nền tảng và tổng quan nghiên cứu liên quan: nút thắt vận hành SOC, cơ sở thống kê và học máy Tầng 1, kiến trúc tác tử và ngôn ngữ lớn Tầng 2, nguy cơ đối kháng AI cùng kỹ thuật kiểm toán mật mã, và khảo sát các hệ thống hiện hành nhằm xác định khoảng trống nghiên cứu mà SENTINEL giải quyết.

2.1 Thực trạng Vận hành SOC và Nút thắt Nhận thức

Chương 1 đã nêu hệ quả vận hành; mục này nêu nguyên nhân kiến trúc của nó. Công tác giám sát an toàn thông tin tại các SOC thu thập nhật ký từ NGFW, IDS/IPS và EDR về hệ thống SIEM tập trung [1], ở khối lượng vượt quá khả năng phân tích thủ công [14]. Bản thân việc gom về một chỗ không phải vấn đề; vấn đề là mọi thiết bị nạp dữ liệu vào đó đều phán quyết bằng chữ ký tĩnh hoặc luật tất định, nên đòn bẩy duy nhất để giảm bỏ lọt là hạ ngưỡng, mà hạ ngưỡng thì sinh ra nhiều cảnh báo hơn chứ không sinh ra cảnh báo tốt hơn [2]. Giải pháp SOAR đứng trên lớp này và tự động hoá phản phản hồi, nhưng một playbook chỉ kích hoạt được với tình huống đã có người lường trước [3].

2.2 Lý thuyết Thống kê Trực tuyến và Học máy Tầng 1

Một tầng chạy ở tốc độ đường truyền áp đặt ràng buộc trước khi áp đặt lựa chọn phương pháp: thứ dựng nên đường nền lưu lượng phải làm việc đó trong thời gian và bộ nhớ hằng số, vì một luồng vô hạn thì không đọc lại được và lịch sử theo từng khoá thì không giữ nổi. Ràng buộc ấy loại bỏ mọi cách tính phương sai hai lượt và chỉ chấp nhận công thức truy hồi tăng dần của Welford [15], trong đó giá trị trung bình μ_k và tổng bình phương độ lệch

S_k được mang theo từng quan sát một:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k}, \quad S_k = S_{k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \quad (2.1)$$

Nhờ đó độ lệch chuẩn $\sigma_k = \sqrt{S_k/(k-1)}$ luôn sẵn sàng ở mọi bước, và điểm Z được đánh giá trên một đường nền không bao giờ phải lưu lại. Hai tính chất có ý nghĩa cho phần sau: đường nền tự thích nghi khi lưu lượng dịch chuyển, và nó làm vậy mà không để lại cửa sổ lưu trữ nào cho kẻ tấn công chờ trôi qua. Các chặng phân loại và lưu đệm dựng trên nền thống kê này được trình bày chi tiết ở Mục 3.3.

2.3 Mô hình Ngôn ngữ Lớn Cục bộ và Trí tuệ Tác tử Tầng 2

Việc chạy tầng suy luận tại chỗ chính là thứ làm nên tính chủ quyền dữ liệu của thiết kế này, và cũng chính là thứ khiến bộ nhớ trở thành ràng buộc siết chặt nhất. Phép tính không khoan nhượng: tám tỉ tham số ở độ chính xác nửa chiếm khoảng 16 GB chỉ riêng cho trọng số, chưa kể kích hoạt và bộ đệm khoá-giá trị, tức đã vượt quá tấm card 16 GB mà luận văn nhắm tới. Lượng tử hoá gồ gút này bằng cách biểu diễn mỗi trọng số trên một lưới số nguyên thô hơn thay vì lưới dấu phẩy động, đánh đổi một lượng trung thực số học có kiểm soát lấy mức giảm dung lượng tương ứng [16]. Ở định dạng GGUF Q4_K_M phục vụ qua `llama.cpp`, mô hình Foundation-Sec-8B-Instruct [17, 18] chiếm 7–8 GB, chừa lại dư địa trên cùng tấm card cho cửa sổ ngữ cảnh và chỉ mục truy xuất. Để điều phối quy trình suy luận, Tầng 2 sử dụng đồ thị trạng thái không chu trình (Acyclic State-Graph) LangGraph [19] tích hợp Bộ nhớ Đe dọa (Threat Memory) lưu trữ lịch sử xâm nhập để liên kết các hành vi đơn lẻ. Việc neo suy luận vào bằng chứng truy xuất được thay vì vào trí nhớ tham số [20] đặt ra một câu hỏi mà lĩnh vực an ninh trả lời khác với hỏi-đáp thông thường: truy vấn ở đây trộn văn xuôi tự do với những token buộc phải khớp theo mặt chữ, như mã kỹ thuật, số hiệu CVE hay giá trị cổng. Tìm kiếm véc-tơ dày [21] xử lý tốt về đầu và không đáng tin ở về sau; khớp từ khoá thừa [22] thì ngược lại. Vì hai bên sinh ra điểm số trên hai thang không so sánh được, chúng được hợp nhất theo **thứ hạng** chứ không theo

điểm—đúng tính chất mà Reciprocal Rank Fusion khai thác [23]:

$$RRF_Score(d) = \sum_{m \in M} \frac{1}{k + r_m(d)} \quad (2.2)$$

truy xuất trực tiếp từ 433 mục STIX MITRE ATT&CK và tài liệu NIST SP 800-61r2 làm căn cứ giải trình pháp y.

2.4 An ninh Đối kháng AI và Mật mã học Kiểm toán Nhật ký

Tích hợp LLM phát sinh nguy cơ bị tấn công tiêm nhiễm câu lệnh qua nhật ký (log-substrate prompt injection) [5], khi kẻ tấn công chen câu lệnh độc hại vào chuỗi User-Agent hoặc tham số URI để thao túng suy luận của AI [7]. Đặc thù của véc-tơ này là **nội dung nhật ký do chính kẻ tấn công soạn ra**: mọi lớp phòng thủ dựa trên nhận dạng nội dung đều là cuộc đua bất tận với biến thể mới. Pandey và Bhujang [24] đo đúng mặt phơi nhiễm này trên một trợ lý phân tích SOC dùng LLM và cho thấy mỗi nguy không nằm ở chỗ trực giác tưởng: câu lệnh ghi đè thẳng thường bị chặn hoàn toàn, trong khi cướp nhân cách vẫn áp chế được **68%** nhật ký độc hại, còn thao túng ngữ cảnh nhắm vào tác vụ tóm tắt thành công **96%** khi không phòng thủ và **38%** ngay cả khi đã ràng buộc đầu ra. Một bộ lọc nhận dạng nội dung được tinh chỉnh cho nhóm dễ thấy vì thế vẫn để ngỏ đúng những nhóm hiệu quả—đó là căn cứ thực nghiệm cho việc phòng thủ véc-tơ này bằng cấu trúc. Để triệt tiêu véc-tơ này về mặt cấu trúc, SENTINEL áp dụng cơ chế Đóng gói Dữ liệu Phân định (Delimited Data Encapsulation) với Nonce ngẫu nhiên cô lập dữ liệu thô, kết hợp rào chắn Guardrail tắt định ép đầu ra mô hình nghiêm ngặt trong ba trạng thái (BLOCK_IP, LOG, AWAIT_HITL).

Nhằm bảo vệ vết pháp y, hệ thống áp dụng kỹ thuật HMAC-SHA256 [25] niêm phong từng bản ghi bằng khóa bí mật cục bộ, tạo thành chuỗi kiểm toán chống thao túng sau xâm nhập. Cần phát biểu chính xác phạm vi bảo chứng: vì HMAC dùng **khóa đối xứng dùng chung**, cơ chế này chứng minh được **tính toàn vẹn và khả năng phát hiện giả mạo**, nhưng **không** cấu thành chống chối bỏ theo nghĩa mật mã học—tính chất đó đòi hỏi chữ ký bất đối xứng. Đây là ranh giới lý thuyết được tôn trọng xuyên suốt luận văn.

2.5 Tổng quan Nghiên cứu Liên quan và Khoảng trống Nghiên cứu

Nghiên cứu ứng dụng trí tuệ nhân tạo trong vận hành an ninh mạng đã tiến triển qua ba nhóm giải pháp kiến trúc chính [26].

Nhóm phòng thủ doanh nghiệp truyền thống gồm các nền tảng SIEM như IBM QRadar và giải pháp SOAR như Palo Alto Cortex XSOAR [1, 3]. Nhóm này tương quan sự kiện bằng tập luật tĩnh và chạy kịch bản định sẵn, nên thất bại khi gặp biến thể mà luật không lường trước. Cái giá của sự cứng nhắc đó đổ lên chuyên viên: qua phỏng vấn người vận hành SOC, AlAhmadi và cộng sự [27] ghi nhận chất lượng cảnh báo là than phiền lớn nhất, với mô tả rằng phần áp đảo cảnh báo không đáng để xử lý. Ưu thế của nhóm này là độ trễ rất thấp—đặc tính mà Tầng 1 của SENTINEL kế thừa thay vì loại bỏ.

Nhóm tác tử phân loại có tăng cường truy xuất tiêu biểu là CyberRAG [28], điều phối các bộ phân loại tinh chỉnh theo từng họ tấn công phía sau một tác tử LLM và công bố độ chính xác trên 94% mỗi lớp trên các phép thử SQL injection, XSS và SSTI. Trọng tâm của công trình này là chất lượng phân loại và lập báo cáo cho những sự kiện đã được chọn để phân tích; nó không giải quyết câu hỏi đứng trước đó—sự kiện nào đáng được phân tích—nên không có tăng tốc độ đường truyền nào chặn nhịp đến của tầng suy luận.

Nhóm đa tác tử và chú trọng quản trị gồm AutoBnB-RAG [29], LanG [30] và Policy-Guided Threat Hunting [31]. Không nên gộp ba công trình này vào một mô tả chung, vì chúng khác nhau đúng ở chiều mà luận văn này đo. AutoBnB-RAG đánh giá phản ứng sự cố đa tác tử có truy xuất trong môi trường trò chơi bàn *Backdoors & Breaches*—một nghiên cứu về phối hợp trong sự cố mô phỏng, không phải về tuyển xử lý sự kiện. LanG là công trình gần luận văn này nhất: cũng dựng trên LangGraph với chốt kiểm có người tham gia, công bố suy luận ≈ 21 ms và thời gian phát hiện trung bình phía máy **1,58 s**, và—trái với bất kỳ khẳng định nào rằng các hệ này không có phòng thủ—đã có sẵn đường rào hai lớp kết hợp biểu thức chính quy với bộ phân loại ngữ nghĩa Llama Prompt Guard 2 đạt F1 **98,1%**. Policy-Guided Threat Hunting cũng đặt các chặng phi-LLM lên trước, dùng bộ tự mã hoá tái dựng và phân loại sơ bộ bằng học tăng cường sâu hai lớp trước khi LLM phân

tích ngữ cảnh.

Vì vậy khoảng trống nghiên cứu hẹp hơn—và trung thực hơn—so với một sự thiếu vắng năng lực ở các công trình đi trước. Mỗi yêu cầu dưới đây đều đã có nơi đáp ứng: phân tầng chi phí ở Policy-Guided Threat Hunting, phòng thủ tiềm nhiệm ở LanG, vận hành cục bộ ở nhiều công trình. Thứ chưa kiến trúc đơn lẻ nào ráp lại được là **tổ hợp**—(1) giải quyết phần lớn lưu lượng ngay tại tầng thống kê/học máy với độ trễ dưới một mili-giây, và công bố tỉ lệ gỡ tải như một **hàm của tỉ lệ tấn công** chứ không phải một hằng số; (2) suy luận có trạng thái chạy cục bộ trên GPU 16 GB dưới một luật neo truy xuất, buộc giữ lại mọi kỹ thuật mà bằng chứng truy xuất được không chống đỡ; và (3) phòng thủ tiềm nhiệm có bảo chứng **cấu trúc**—suy ra từ vị trí đặt văn bản do kẻ tấn công soạn so với ranh giới chỉ thị, nên độc lập với câu chữ của payload, khác với một bộ phân loại xác suất dù điểm số cao đến đâu—cùng với niêm phong pháp y HMAC-SHA256. Bảng 1 đối chiếu chi tiết SENTINEL với các nhóm đại diện.

Bảng 1. Bảng so sánh đối chiếu giữa SENTINEL và các giải pháp phòng thủ hiện hành

Tiêu chí Đánh giá	SIEM / SOAR (QRadar, XSOAR)	Hệ tác tử LLM (CyberRAG, LanG, Policy-Guided)	Kiến trúc SENTINEL (Luận văn)
Kỹ thuật Cốt lõi	Tập luật tương quan tĩnh, kịch bản Python/JS cứng	RAG tác tử, điều phối đa tác tử, phân loại sơ bộ bằng DRL	Bộ lọc Welford $\mathcal{O}(1)$ + LightGBM T1, LangGraph Agent T2
Mục tiêu Vận hành	Gom nhật ký tập trung và phản hồi theo kịch bản	Tự động hóa điều tra sự cố bằng suy luận ngôn ngữ	Giải quyết lưu lượng tại tầng rẻ, dành tầng đắt cho ca cần suy luận
Phân tầng chi phí	Một tầng rẻ, không có suy luận	Có ở một số công trình (phân loại sơ bộ DRL), vắng ở số khác; gỡ tải không công bố theo tỉ lệ tấn công	Hai tầng : rẻ trước, đắt sau; gỡ tải công bố trên hai tỉ lệ tấn công
Chủ quyền Dữ liệu	Cục bộ nội bộ	Có công bố triển khai cục bộ; khung phần cứng không phải lúc nào cũng nêu	Air-gapped 100% trên GPU 16 GB
Chống Prompt Inj.	Không áp dụng	Bộ phân loại xác suất (LanG: regex + Prompt Guard 2, F1 98,1%)	Bảo chứng cấu trúc, độc lập với câu chữ payload
Kiểm toán Pháp y	Nhật ký văn bản tiêu chuẩn (dễ bị chỉnh sửa)	Không thấy công bố	Chuỗi HMAC-SHA256 phát hiện giả mạo

Chương 3

Thiết kế Hệ thống và Triển khai Kỹ thuật

Chương này trình bày phương pháp nghiên cứu, sau đó đi vào thiết kế kiến trúc và giải pháp triển khai của hệ thống SENTINEL: luồng xử lý phân tầng, bộ lọc đường truyền Tầng 1 cùng Cổng Học máy, kiến trúc suy luận tác tử Tầng 2 và Bộ nhớ Đe dọa, cơ chế truy xuất tri thức Dual-RAG, giải pháp an ninh đối kháng cùng kỹ thuật kiểm toán mật mã, và phương án triển khai cục bộ.

3.1 Phương pháp Nghiên cứu

Luận văn theo phương pháp Nghiên cứu Khoa học Thiết kế (DSR): đóng góp là một sản phẩm nhân tạo, và sản phẩm ấy được đánh giá bằng đo đạc chứ không bằng lập luận. Ba bình diện cấu thành quá trình xây dựng. **Bình diện thống kê và học máy** cung cấp năng lực lọc ở tốc độ đường truyền qua thuật toán Welford $\mathcal{O}(1)$ tính Z -score trực tuyến, tiếp nối bằng phân loại LightGBM. **Bình diện logic tác tử** cung cấp năng lực suy luận theo ngữ cảnh qua đồ thị trạng thái LangGraph điều phối một mô hình ngôn ngữ lưu trữ cục bộ trên nền truy xuất lai FAISS/BM25/RRF. **Bình diện bảo mật đối kháng** cung cấp ranh giới phòng thủ, thử ứng suất khả năng kháng tiêm nhiễm câu lệnh và kiểm tra toàn vẹn vết nhật ký. Hiệu quả được đánh giá trên năm chiều—chất lượng phân loại, hiệu năng xử lý, khả năng kháng đối kháng, độ nhất quán của căn cứ giải thích do mô hình độc lập chấm, và toàn vẹn vết kiểm toán—ánh xạ đúng vào ba câu hỏi nghiên cứu ở Mục 1.2 và ba mục kết quả của Chương 4.

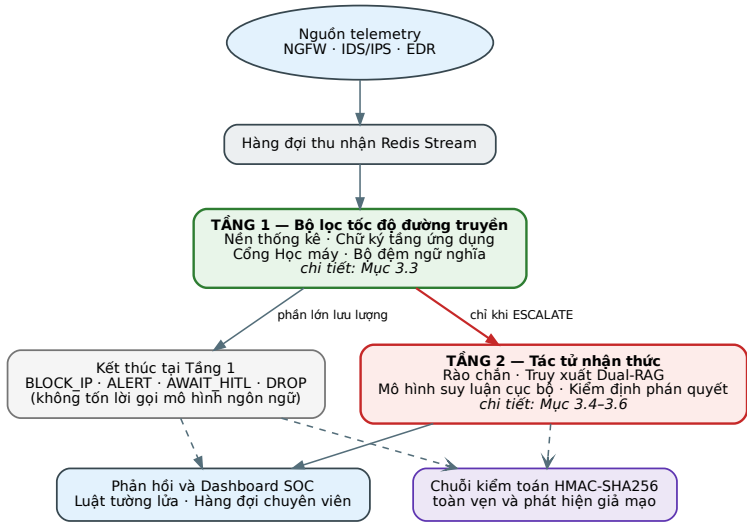
Ba nguyên tắc đo lường chi phối mọi con số trong luận văn: **mẫu số phải khớp câu hỏi**, thước đo phải **miễn nhiễm với tỉ lệ nền** (MCC và Balanced Accuracy thay vì Accuracy hay

$F1$ nhị phân), và mọi tỉ lệ đều phải báo **kèm mẫu số và độ phủ phép đo**. Hệ quả của chúng đủ nghiêm trọng để được phân tích tại đúng chỗ chúng phát huy tác dụng, ở Mục 4.1.

3.2 Kiến trúc Tổng thể SENTINEL và Tích hợp Ngăn xếp SOC

SENTINEL áp dụng Kiến trúc Nhận thức Hai tầng với nguyên lý thiết kế cốt lõi là phân tách nhiệm vụ tính toán theo chi phí: Tầng 1 vận hành các thuật toán thống kê và học máy phi trạng thái để giải quyết dứt điểm phần lớn lưu lượng ở tốc độ đường truyền; Tầng 2 vận hành cỗ máy tác tử ngôn ngữ có trạng thái nhằm suy luận ngữ cảnh sâu cho các sự kiện dị thường phức tạp.

Hình 1 trình bày kiến trúc chỉ ở mức khối. Nhật ký thô từ các nguồn giám sát ranh giới được nạp vào hàng đợi Redis Stream rồi chuyển cho Tầng 1, nơi giải quyết dứt điểm phần lớn lưu lượng; chỉ những sự kiện mang nhãn ESCALATE mới đi tiếp lên Tầng 2, và mọi phán quyết từ cả hai tầng đều được niêm phong vào cùng một chuỗi kiểm toán. Cấu trúc bên trong mỗi khối được cố ý lược bỏ ở đây và phóng to ở đúng mục ghi trên chính khối đó, để người đọc mỗi lúc chỉ phải tiếp nhận một mức trừu tượng.



Hình 1. SENTINEL ở mức khối: hai tầng tách nhau theo chi phí, với một đường leo thang duy nhất nối giữa. (Nguồn: Tác giả)

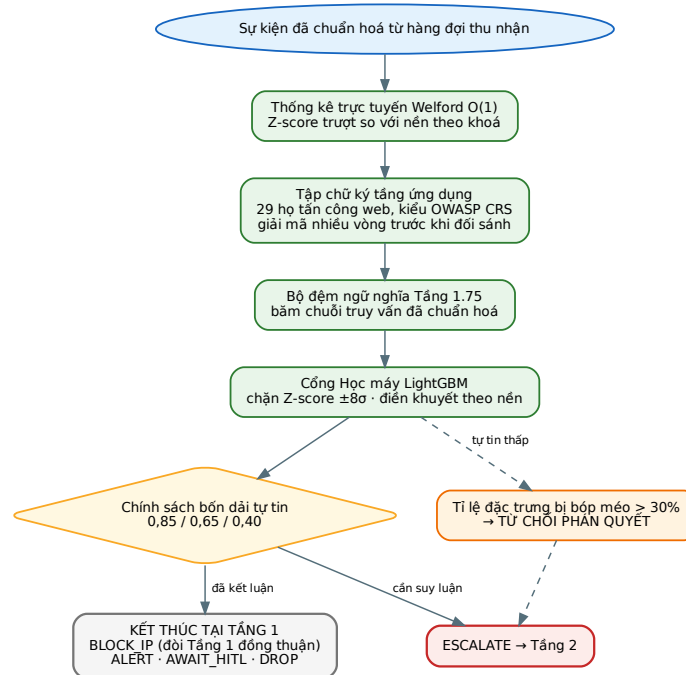
Một điểm thiết kế quyết định cần nêu rõ: trong danh mục hành động của Tầng 1, **chỉ**

trạng thái ESCALATE mới dẫn tiếp lên Tầng 2. Các phán quyết BLOCK_IP, ALERT, AWAIT_HITL và DROP đều **kết thúc tại Tầng 1.** Đây là cơ sở để định nghĩa tỉ lệ xả tải ở Chương 4: một sự kiện được xem là đã gỡ tải khi nó không phát sinh lời gọi mô hình ngôn ngữ, bất kể phán quyết cuối là chặn hay bỏ qua.

Tại Tầng 2, cỗ máy tác tử LangGraph kích hoạt chuỗi suy luận bằng mô hình Foundation-Sec-8B-Instruct cục bộ, kết hợp lịch sử từ Bộ nhớ Đe dọa và tri thức truy xuất từ Dual-RAG. Phán quyết cuối được kiểm soát bởi rào chắn tất định giới hạn trong ba trạng thái, và mọi bản ghi đều được niêm phong bằng chuỗi băm HMAC-SHA256. Trong ngăn xếp SOC doanh nghiệp, SENTINEL vì vậy đóng vai trò middleware nhận thức đứng giữa nền tảng thu thập SIEM và công cụ thực thi tường lửa/SOAR: hấp thụ lưu lượng nhiều tại Tầng 1 và cung cấp căn cứ giải trình có trích dẫn cho sự kiện leo thang, đồng thời bảo đảm chủ quyền dữ liệu nhờ vận hành air-gapped hoàn toàn trên GPU đơn 16 GB VRAM.

3.3 Tầng 1: Bộ lọc Tốc độ Đường truyền và Cổng Học máy

Tầng 1 là rào chắn phi trạng thái đầu tiên, kết hợp bộ lọc thống kê Welford $\mathcal{O}(1)$ (Công thức 2.1) với Cổng Học máy LightGBM nhằm bảo đảm độ trễ mili-giây trước khi kích hoạt GPU. Hình 2 phóng to đúng khối tương ứng của Hình 1.



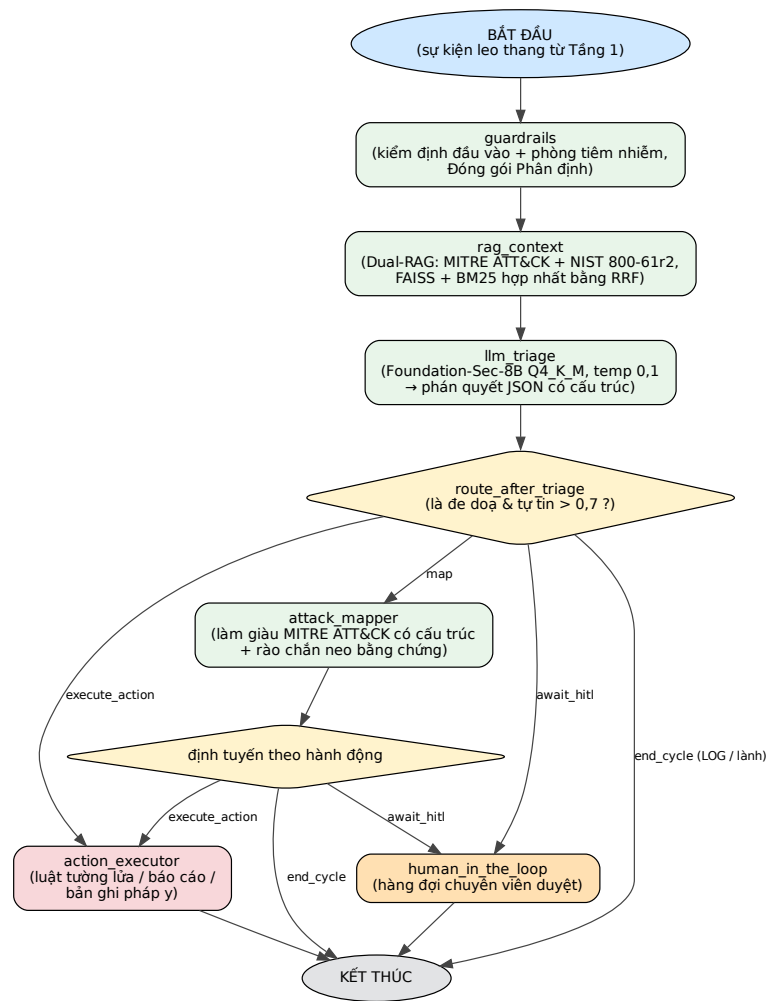
Hình 2. Tầng 1 phóng to. Chỉ nhánh ESCALATE đi tới Tầng 2; mọi phán quyết khác kết thúc tại đây, và đó chính là thứ Chương 4 tính là xả tải. (Nguồn: Tác giả)

Bộ lọc thống kê tính $Z = (x - \mu) / \sigma$ theo thời gian thực trên các đặc trưng lưu lượng (tần suất gói tin, dung lượng luồng, thời lượng kết nối), với μ và σ cập nhật theo công thức truy hồi ở Mục 2.2 mà không lưu lịch sử thô [15]; lưu lượng tuân theo phân bố nền bị loại ngay lập tức. Bên cạnh nhánh thống kê, Tầng 1 vận hành tập chữ ký ứng dụng gồm **30 họ tấn công web** với chuẩn hoá đa vòng theo lỗi OWASP CRS—giải mã URL và thực thể HTML trước khi khớp mẫu—nhằm bắt payload nguy trang bằng mã hoá. Để tập chữ ký này không chỉ là lời tự khai, mỗi họ được neo vào hai khung tham chiếu công khai: **23 trong 30** họ ảnh xạ được sang tập luật OWASP CRS 3.3 (11 tập khác nhau) và tập chữ ký phủ đủ **10** hạng mục OWASP Top 10:2021. Bảy họ còn lại không có đối ứng CRS **do bản chất, không phải do bỏ sót**—ransomware, đào tiền mã hoá, đánh cắp thông tin xác thực, tệp nhị phân sẵn có của hệ điều hành và reverse shell là hành vi ở tầng endpoint và mạng, nằm ngoài phạm vi một bộ luật viết cho giao dịch HTTP. Đối với hành vi lặp lại diện rộng, Semantic Cache Tầng 1.75 băm chuỗi truy vấn đã chuẩn hoá trong RAM và tái sử dụng phán quyết có sẵn.

Cổng Học máy LightGBM tiếp nối, đánh giá các tương tác đặc trưng phi tuyến. Mô hình dùng cây phát triển theo lá, huấn luyện trên 949.535 mẫu NetFlow (664.674 huấn luyện, 189.907 hold-out). Nhằm triệt tiêu né tránh học máy, Cổng ML kẹp Z -score trong $\pm 8\sigma$ và điền giá trị thiếu bằng trung bình baseline; nếu tỷ lệ đặc trưng biến dạng vượt 30%, nó **từ chối phán quyết** và nâng cấp lên Tầng 2. Abstain là lựa chọn có chủ đích: một câu trả lời sai kèm độ tin cậy cao nguy hiểm hơn lời thú nhận không biết, vì nó khiến hệ tự hành động mà không ai kiểm lại. Phán quyết được ánh xạ sang hành động theo **chính sách bốn dải độ tin cậy** (0,85 / 0,65 / 0,40 tương ứng BLOCK_IP / ESCALATE / ALERT / LOG), bảo đảm độ tin cậy *quyết định* hành động thay vì chỉ được ghi kèm, và cô lập phần tự động chặn vào dải cao nhất—nơi còn đòi hỏi sự đồng thuận của luật Tầng 1.

3.4 Tầng 2: Tác tử Nhận thức LangGraph và Bộ nhớ Đe dọa

Tầng 2 đảm nhận suy luận nhận thức có trạng thái, vận hành mô hình Foundation-Sec-8B-Instruct [17, 18] lượng tử hoá theo cách đã trình bày ở Mục 2.3, phục vụ bởi llama.cpp biên dịch cờ CUDA trên GPU cục bộ 16 GB VRAM. Hình 3 phóng to khối Tầng 2 của Hình 1.



Hình 3. Đồ thị trạng thái tác tử Tầng 2, phản ánh đúng `src/agent/workflow.py`: đồ thị không chu trình, mọi đường đi đều kết thúc ở một hành động đã thực thi, một lần chuyển chuyên viên, hoặc kết thúc chu kỳ. (Nguồn: Tác giả)

Quy trình được điều phối bởi đồ thị LangGraph [19] qua năm trạm: lọc rào chắn (guardrails), làm giàu ngữ cảnh (rag_context), phân loại sơ bộ (llm_triage), ánh xạ kỹ thuật (attack_mapper), và thực thi (action_executor hoặc human_in_loop). Trạm ánh xạ đòi hỏi căn cứ xác thực từ kho tri thức; nếu không có mã kỹ thuật phù hợp rõ ràng, đồ thị định tuyến sang kiểm duyệt chuyên gia (AWAIT_HITL) thay vì đoán mò. Đường chuyển-người là một đầu ra thiết kế, không phải thất bại: hệ thống phân loại việc cần người chứ không thay thế người. Tại llm_triage, hệ thực hiện gỡ nhãn (label stripping), loại mọi trường phân loại nội bộ khỏi prompt—điều kiện tiên quyết cho tính hợp lệ của mọi số đo ở Chương 4, vì nhãn thật lọt vào ngữ cảnh sẽ khiến

mô hình chép đáp án chứ không suy luận.

Hai cơ chế giới hạn thứ được phép đi vào chu trình suy luận đó. Các sự kiện lặp lại trước hết bị gom bởi **Drain**—kỹ thuật khai phá khuôn mẫu nhật ký trực tuyến [32]—nhóm những bản ghi gần trùng về cùng một khuôn, nhờ đó một đợt bùng nổ một nghìn dòng tương tự tồn của cửa sổ ngữ cảnh xấp xỉ chi phí của một dòng. Tiếp đó, **bộ giám sát ngân sách token** ước lượng trước mỗi lần gọi và ghi lại lượng token thật do máy chủ trả về sau đó, để việc tiến sát trần ngữ cảnh là một điều kiện **quan sát được và có ghi nhật ký**, không phải một lần cắt cụt âm thầm. Mục 4.3 báo cáo kết quả của cặp cơ chế này trước một đầu vào cố ý làm quá khổ.

Để liên kết hành vi rải rác theo thời gian, Tầng 2 duy trì Bộ nhớ Đe dọa trên SQLite tối ưu chỉ mục, cấu hình `synchronous=NORMAL` với `rollback-journal` thay cho WAL nhằm tránh xung đột quyền truy cập cross-UID trong Docker. Bộ nhớ quản lý uy tín IP (`ip_reputation`), thực thể nội bộ (`known_entities`), chỉ báo rủi ro (`apt_indicators`) và sự kiện đe dọa (`threat_events`). Điểm uy tín S suy giảm theo thời gian im lặng t :

$$S_{\text{new}} = S_{\text{old}} \times (1 - \lambda)^t \quad (3.1)$$

với λ là hệ số suy giảm. Khi đạt ngưỡng tối đa ($S = 100$), Tầng 1 áp dụng chặn ngay lập tức cho kết nối tiếp theo mà không kích hoạt lại Tầng 2—khép kín vòng phản hồi tự động, biến chi phí suy luận một lần thành phán quyết dùng lại được nhiều lần. Các IP hạ tầng nội bộ nằm trong danh sách trắng cứng, miễn nhiệm với lệnh chặn nhằm ngăn tự từ chối dịch vụ.

3.5 Cơ chế Truy xuất Tri thức Lai Dual-RAG

Để hạn chế hư cấu và bảo đảm minh bạch cho quyết định an ninh, Tầng 2 tích hợp Dual-RAG trên kho 433 mục MITRE ATT&CK chuẩn STIX 2.1 [33] cùng tài liệu NIST SP 800-61r2 [34]. Truy xuất chạy song song hai cơ chế hỗ trợ: tìm kiếm ngữ nghĩa bằng vector FAISS [21] với mô hình Sentence-BERT [35], phát hiện các kỹ thuật cùng bản chất nhưng

khác từ khóa; và tìm kiếm từ khóa thừa BM25 [22], bảo đảm khớp chính xác các định danh như mã CVE, khóa Registry hoặc số hiệu cổng. Kết quả được hợp nhất bằng RRF (Công thức 2.2) với $k = 60$ rồi chèn vào ngữ cảnh tại `rag_context`. Hình 4 thể hiện đường truy xuất cùng phép kiểm neo áp lên đầu ra của mô hình.



Hình 4. Truy xuất Dual-RAG và rào chắn neo bằng chứng. Phép kiểm nằm ở phía đầu ra: nó ràng buộc thứ mô hình được phép khẳng định, không phải thứ bộ truy xuất được phép trả về. (Nguồn: Tác giả)

Bản thân truy xuất cũng là một ranh giới tin cậy, vì một mục tri thức bị đầu độc sẽ được mô hình đọc như nguồn có thẩm quyền. Vì vậy một **bộ khử độc RAG** chuẩn hoá Unicode, bóc thẻ đánh dấu và vô hiệu hoá các cấu trúc mệnh lệnh trong mọi đoạn văn truy xuất được trước khi chúng vào prompt. Khó khăn nằm ở chỗ văn xuôi an ninh hợp lệ vốn viết ở thể mệnh lệnh—các bản khuyến cáo bảo người đọc hãy chặn, hãy tắt, hãy cô lập—nên một bộ lọc quá tay sẽ âm thầm làm hỏng chính kho tri thức mà nó bảo vệ; Mục 4.3 báo cáo tỉ lệ vô hiệu hoá oan đo trên toàn bộ kho.

Trên nền truy xuất này, hệ thống áp dụng **rào chắn neo bằng chứng**: mọi mã kỹ thuật do mô hình công bố đều bị đối chiếu ngược với tập tài liệu đã truy xuất của chính lô đó; mã không hiện diện bị ép về N/A và chuyển `AWAIT_HITL`. Đây là ràng buộc **kiểm chứng được của kiến trúc**, không phụ thuộc vào xu hướng hư cấu của mô hình cụ thể—và chính là ranh giới phân biệt một hệ thống có tri thức với một lớp bọc quanh mô hình ngôn ngữ.

3.6 Kiến trúc An ninh AI và Niêm phong Kiểm toán Mật mã

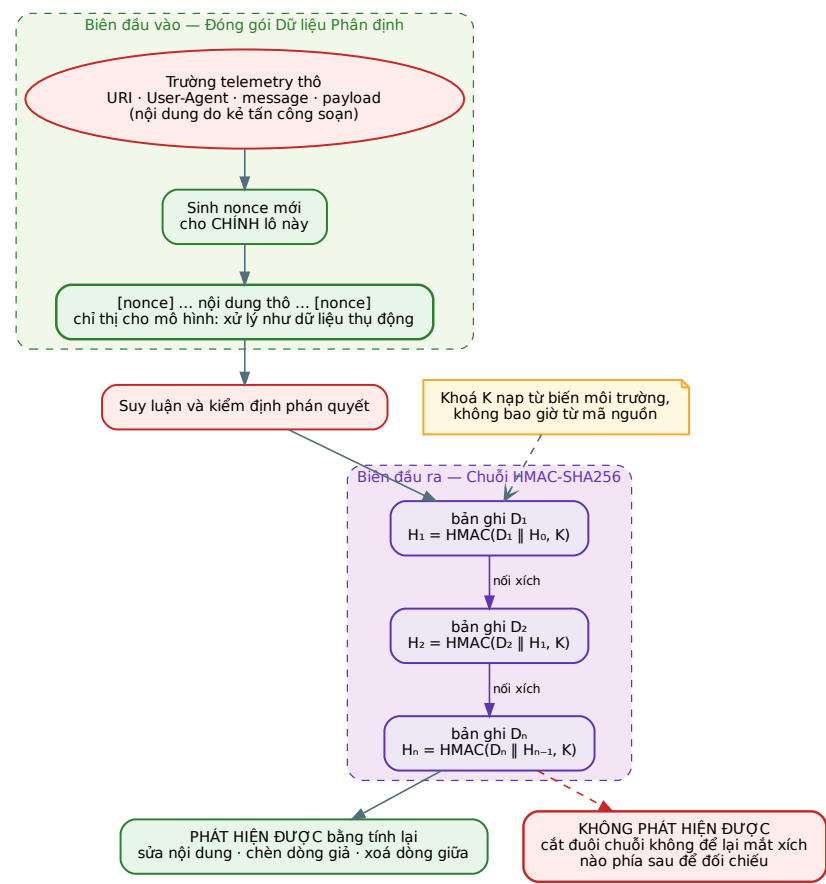
Tiêm nhiễm câu lệnh qua nhật ký [5] là kỹ thuật chèn câu lệnh điều khiển vào các trường nhật ký thô (User-Agent, URI, nội dung Syslog) nhằm chiếm quyền điều khiển hành vi mô hình. SENTINEL áp dụng Đóng gói Dữ liệu Phân định với nonce mật mã sinh mới cho mỗi lô xử lý [7]: toàn bộ nhật ký thô được bọc trong cặp thẻ chứa nonce, buộc mô hình xử lý nội

dung bên trong như văn bản thuần túy. Sinh nonce theo từng lô—thay vì dùng chuỗi phân định cố định—là bắt buộc, vì dấu phân định bất biến có thể bị suy ra từ mã nguồn hoặc quan sát lặp lại, khi đó kẻ tấn công có thể tự đóng vùng bọc để thoát ra. Song song, ba bộ thẩm định tất định canh giữ các ranh giới mà mô hình ngôn ngữ có thể chạm tới. **Bộ thẩm định dữ liệu** loại bỏ nhật ký dị dạng trước khi nó kịp được đóng khung thành prompt. **Bộ thẩm định quyết định** ép phán quyết tuân thủ cấu trúc Pydantic (`LLMDecision`), ràng buộc hành động trong tập giá trị cho phép và từ chối lệnh chặn nhắm vào dải địa chỉ nội bộ hoặc dải dành riêng; khi định dạng lỗi, cơ chế phục hồi bằng Regex trích xuất trường cốt lõi hoặc chuyển về trạng thái an toàn `AWAIT_HITL`. **Bộ thẩm định phản hồi** áp cùng thể trận zero-trust lên chính những luật mà hệ tự đề xuất cho mình, để một phán quyết bị thao túng không thể cài được luật vĩnh viễn vào Tầng 1.

Về kiểm toán, mỗi bản ghi phán quyết thứ i được liên kết chuỗi bằng HMAC-SHA256 [25]:

$$H_i = \text{HMAC-SHA256}(D_i \parallel H_{i-1}, K) \quad (3.2)$$

trong đó D_i là dữ liệu bản ghi hiện tại, H_{i-1} là băm bản ghi liền trước, và K là khóa bí mật nạp từ biến môi trường—không mã hoá cứng trong nguồn, vì khóa lộ trong mã khiến toàn chuỗi có thể bị làm giả lại từ đầu. Liên kết chuỗi khiến mọi sửa đổi hay xóa bản ghi giữa chuỗi làm đứt gãy tính liên tục và bị phát hiện tức thì—bảo đảm toàn vẹn và phát hiện giả mạo, song không phải chống chối bỏ, vì lý do khoá đối xứng đã nêu ở Mục 2.4. Hình 5 đặt cả hai cơ chế mật mã lên cùng một sơ đồ, mỗi cơ chế ở một biên của tầng suy luận.



Hình 5. Đóng gói nonce ở biên đầu vào và chuỗi HMAC ở biên đầu ra. Điểm mù cắt đuôi được vẽ ra chứ không lược đi, vì nó là hệ quả của chính cấu trúc. (Nguồn: Tác giả)

3.7 SOC Dashboard và Kiến trúc Triển khai Cục bộ

Bảng điều khiển SOC Analyst Dashboard được xây dựng trên Streamlit, kết nối trực tiếp Redis Stream và Bộ nhớ Dữ liệu để cung cấp góc nhìn thời gian thực: phổ xử tải theo từng tầng, dòng thời gian chuỗi tấn công đa giai đoạn, chỉ báo toàn vẹn chuỗi HMAC, và bảng kiểm duyệt HITL. Nhịp nạp dữ liệu được điều tiết bằng backpressure đo theo **độ trễ của consumer-group**—số entry đã công bố nhưng consumer chưa nhận. Khác biệt này không phải chuyện hình thức: vì subscriber tiêu thụ bằng XREADGROUP và XACK, hai thao tác đều không xoá entry, nên độ dài stream luôn dính sát ngưỡng trần dù consumer xử lý nhanh đến đâu, và một producer tự hãm theo độ dài stream sẽ treo vĩnh viễn trước một hàng đợi thực ra đã trống. Toàn bộ dịch vụ đóng gói bằng Docker Compose; llama.cpp biên

dịch cờ CUDA cho card RTX 4060 Ti; `threat_memory.db` và chỉ mục FAISS gắn trên Docker Volume độc lập để điểm uy tín IP và vết pháp y sống sót qua tái khởi động.

Thiết kế tuân thủ chuẩn Zero Trust [6]: chuỗi mật khẩu trong `REDIS_URL` được che phủ trước khi ghi log. Nhằm chịu tải khi lưu lượng tăng đột biến, hệ thống áp dụng backpressure dựa trên **độ tồn đọng (lag) của Redis consumer group** thay vì độ dài hàng đợi: độ dài một stream chỉ tăng lên kể cả khi mọi bản ghi đã xử lý xong, nên điều tiết theo nó sẽ bóp nghẹt nguồn phát vĩnh viễn, trong khi tồn đọng của consumer group phản ánh đúng phần công việc còn lại.

Chương 4

Thực nghiệm và Đánh giá

Chương này trình bày kết quả thực nghiệm định lượng đối với hệ thống SENTINEL, tổ chức theo đúng ba câu hỏi nghiên cứu đặt ra ở Chương 1. Mỗi mục nêu chỉ số đo được, mẫu số của phép đo, và giới hạn của kết luận rút ra từ chỉ số đó.

4.1 Môi trường Thực nghiệm và Giao ước Đo lường

Hệ thống được triển khai trên máy chủ cục bộ đại diện cho SOC doanh nghiệp vừa và nhỏ, toàn bộ vi dịch vụ ảo hóa bằng Docker Compose trong môi trường air-gapped. Nguyên tắc phương pháp luận xuyên suốt là **mẫu số phải khớp câu hỏi**: chỉ số phụ thuộc phân bố lưu lượng (tỉ lệ xả tải) đo trên luồng thực, chất lượng phân loại đo trên tập cân bằng lớp. Trộn hai loại này là nguồn sai lệch nghiêm trọng—do tỉ lệ xả tải trên tập ép cân bằng 50/50 sẽ cho kết quả thấp giả tạo, vì tập đó không phản ánh phân bố mà hệ thống thực sự gặp. Bảng 2 nêu rõ vai trò từng tập.

Hai nhóm phép kiểm được báo cáo tách khỏi các bảng chỉ số vì chúng là **phép kiểm chức năng, không phải phép đo**: một lượt audit năng lực từng tầng xác nhận mỗi tầng đều tới được và hành xử đúng đặc tả (15/15 phép kiểm đạt), và một lượt audit cơ chế gỡ tải xác nhận mỗi đường gỡ tải đã ghi trong tài liệu đều thực sự kích hoạt (14/14). Chúng trả lời câu hỏi “đường ống đã nối đúng chưa” chứ không phải “chạy tốt đến đâu”, và đặt một tỉ lệ đạt cạnh các con số hiệu năng thật sẽ khiến người đọc thổi phồng nhóm sau bằng liên tưởng.

Hai giao ước bổ sung áp dụng cho mọi lượt đo. Thứ nhất, luật động bị **đóng băng** trong suốt phép đo, tránh việc phép đo tự sinh luật rồi tự hưởng lợi ở vòng sau. Thứ hai, 50 mẫu do tác giả biên soạn lẫn trong `ground_truth.json` bị loại khỏi mọi tỉ lệ—nếu giữ lại,

Bảng 2. Cấu hình Thực nghiệm và Phân vai Tập Dữ liệu

Thành phần	Thông số	Vai trò trong phép đo
Vi xử lý (CPU)	Intel Core i7	Bộ lọc Welford và luồng Redis
Bộ nhớ RAM	32 GB DDR5	Semantic Cache và chỉ mục FAISS
Card đồ họa (GPU)	RTX 4060 Ti 16 GB	llama.cpp CUDA, Foundation-Sec-8B-Instruct [18]
Ảo hóa	Docker Compose	Môi trường air-gapped, tái lập được
datatest.json	4.240 → 4.236 khi chấm , 51,8% tần công	Chất lượng phân loại Cổng ML. Trích từ CSE-CIC-IDS2018 [8], CSIC 2010 [9] và DAPT 2020 [10]. Không dùng cho tỉ lệ xả tải
ground_truth.json	1.750 mẫu → 1.700 khi chấm	Ablation, chất lượng lập luận. 50 mẫu tác giả biên soạn bị loại khỏi mọi tỉ lệ
build_stream()	25.799 (150 khởi động + 25.649 chấm), 31,6% tần công	Tỉ lệ xả tải, toàn tuyến
Luồng dạng SOC	99.717 sự kiện, 9,8% tần công	Tỉ lệ xả tải ở base-rate gần thực tế
Tập đối kháng	823 = 703 công bố + 80 tự soạn + 40 kiểm chéo	AdvBench [11], deepset [12] và một tập jailbreak [13] có nguồn gốc từ nghiên cứu thực địa của Shen và cộng sự [36]. Ba xuất xứ chấm tách bạch, không bao giờ gộp

chúng chiếm 16,7% tập chấm quy kết và toàn bộ cùng một đáp án, làm lệch phân bố nhãn.

4.2 RQ1 — Xả tải và Kinh tế học Tầng lọc

Mục này báo cáo **Mục tiêu 1 / RQ1** của Mục 1.2, theo các nguyên tắc đo lường ở Mục 3.1. RQ1 gồm ba vế: xả tải ở tốc độ đường truyền, cắt độ trễ, và giảm tiêu thụ tài nguyên. Như đã nêu ở Mục 3.2, một sự kiện được tính là **đã gỡ tải** khi nó không phát sinh lời gọi mô hình ngôn ngữ—mọi hành động khác ESCALATE đều kết thúc tại Tầng 1. Định nghĩa này quan trọng vì cách đếm chỉ tính DROP sẽ bỏ sót BLOCK_IP, ALERT và AWAIT_HITL—vốn cũng không tiêu tốn một token nào.

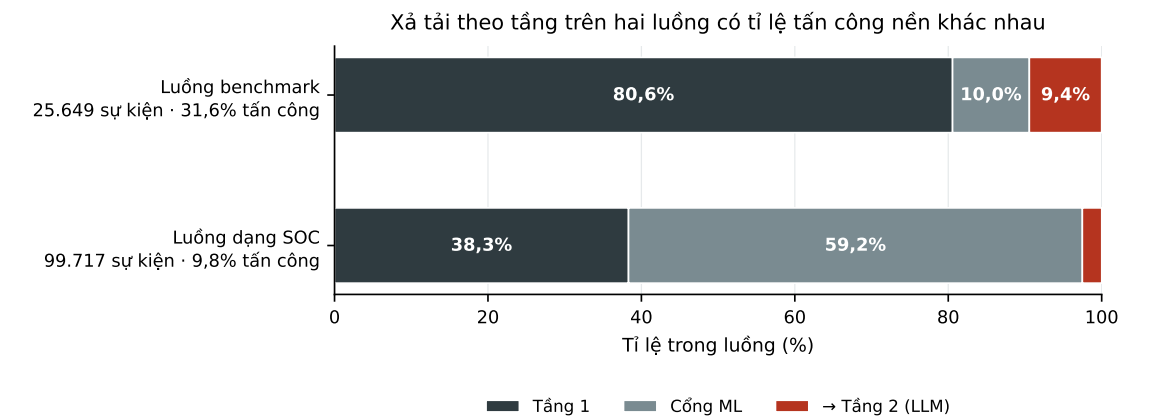
Bảng 3. Tỷ lệ Xả tải theo Từng Tầng trên Hai Luồng có Base-rate Khác nhau

Tầng giải quyết	Luồng benchmark 25.649 sk		Luồng dạng SOC 99.717 sk	
	Số sự kiện	Tỷ lệ	Số sự kiện	Tỷ lệ
Tầng 1 (luật + Welford + chữ ký)	20.663	80,6%	38.207	38,3%
Cổng Học máy (LightGBM 4 dải)	2.568	10,0%	58.992	59,2%
Cộng dồn — không chạm LLM	23.231	90,6%	97.199	97,5%
Còn lại → Tầng 2 (LLM)	2.418	9,4%	2.518	2,5%
<i>Tỷ lệ tấn công của luồng</i>	<i>31,6%</i>		<i>9,8%</i>	

Kết quả ở Bảng 3 cho thấy một đặc tính chưa được phát biểu tường minh trong các công trình liên quan: **tỷ lệ xả tải là hàm của tỷ lệ tấn công trong luồng, không phải hằng số của hệ thống**. Trong phạm vi một luồng, tỷ lệ tổng tách tuyến tính thành xả tải(p) = $(1 - p) \cdot \text{xả tải}_{\text{lành}} + p \cdot \text{xả tải}_{\text{tấn công}}$ với p là tỷ lệ tấn công. Trên luồng benchmark, hai tỷ lệ theo nhãn là **92,35%** với ca lành và **86,72%** với ca tấn công, tái lập đúng con số 90,6% đo được; trên luồng dạng SOC, hai tỷ lệ là **97,88%** và **93,77%**, tái lập đúng 97,5%. Bản thân hai hệ số khác nhau giữa hai luồng vì thành phần lưu lượng của chúng khác nhau, nên quan hệ này cho phép chiếu sang tỷ lệ tấn công khác **trong cùng một luồng**—chứ không cho phép mang hệ số của luồng này áp sang luồng kia. Vì vậy con số 90,6% trên luồng benchmark **không phải giới hạn kiến trúc** mà là hệ quả của việc luồng thử cố ý nhồi tấn công gấp hơn ba lần thực tế.

Một quan sát thứ hai: **tầng gánh chính đổi theo luồng**. Ở luồng benchmark, luật Tầng 1 giải quyết 80,6%; ở luồng lành áp đảo, Cổng ML mới là tầng gánh chính với 59,2%. Hai

tầng bù trừ cho nhau chứ không chồng lấn—căn cứ thực nghiệm cho việc phải có cả hai. Hình 6 cho thấy rõ sự đảo vai đổ.



Hình 6. Cơ cấu xả tải trên hai luồng. Tầng gánh chính đảo vai theo tỉ lệ tấn công nền. Sinh từ `offload_vs_baserate_{stream,demo}.json`. (Nguồn: Tác giả)

Tiết kiệm theo từng thành phần. Cổng ML xử lý mỗi véc-tơ trong **0,287 ms**, đạt **3.452 sự kiện/giây**. Bộ đệm ngữ nghĩa Tầng 1.75 đạt tỉ lệ trùng **81,3%** (1.220/1.500 truy vấn) với hệ số tăng tốc **8,9×** và không có lần trực xuất nào; khóa đệm là băm của chuỗi truy vấn đã chuẩn hoá—khớp chính xác chứ không phải tương đồng embedding—nên tỉ lệ trùng đến từ việc nhiều sự kiện khác nhau quy về cùng một mô tả dịch vụ/cổng/kỹ thuật. Một chỉ số chất lượng thuộc về đúng mục này chứ không phải mục bên cạnh, vì nó là điều kiện cạnh của chính tuyên bố xả tải: tỉ lệ 90,6% cũng đọc được theo nghĩa “cho qua gần hết” nếu phần được xả tải không được phán quyết đúng. Trên `datatest.json`, Cổng ML đạt **MCC 0,667** và **Balanced Accuracy 0,833**—chủ ý dùng MCC thay Accuracy, vì một bộ dò chỉ cần đoán “lạnh” cho mọi sự kiện đã đạt Accuracy **90,2%** trên luồng dạng SOC mà không phân biệt được gì. Mẫu số phải nêu kèm con số: trong 4.236 sự kiện đi vào, Cổng ML chỉ tự phán quyết **2.534** ca, tức tỉ lệ bỏ qua **59,8%**—1.586 ca thiếu đặc trưng payload mà mô hình cần và 116 ca từ chối phán quyết—nên các chỉ số chất lượng này mô tả đúng phần đã phán quyết đó, không phải cả tệp. Phần **tự động chặn không cần người** gồm 962 lệnh đạt **Precision 100%**, **không báo động giả nào**. Điều kiện sau là bắt buộc: xả tải mà chặn nhầm khách thật thì không phải hiệu quả mà là tổn thất.

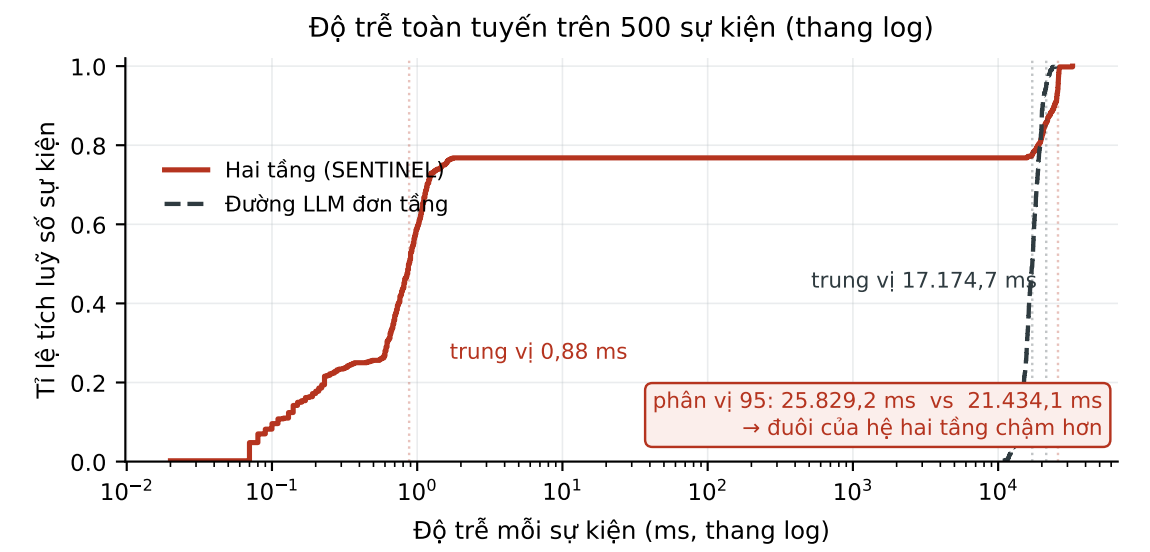
Vòng phản hồi Tầng 2 → Tầng 1. Cơ chế xả tải thứ tư được kiểm chứng bằng thực nghiệm hai vòng trên cùng hạt giống. Sau khi thu 598 luật từ phán quyết chặn của Cổng ML, tỉ lệ

leo thang giảm từ **20,28% xuống 17,98%** (giảm tương đối **11,35%**, tức 594 sự kiện được Tầng 1 hấp thụ thêm), trong khi chất lượng phát hiện **tăng** chứ không giảm: MCC +0,0378, Recall +0,0452. Điểm này đáng chú ý vì cơ chế học từ phán quyết thường đánh đổi độ chính xác lấy tốc độ; ở đây cả hai cùng cải thiện. Hai điều kiện giữ cho tuyên bố đúng tầm. Giá trị MCC tuyệt đối vẫn thấp—0,071 $\rightarrow$ 0,109—nên thực nghiệm chứng minh cơ chế *vận hành được*, không chứng minh Tầng 1 là bộ phân loại mạnh. Và mô phỏng lạc quan ở hai điểm: kẻ tấn công không đổi địa chỉ nguồn giữa hai vòng, còn chuyên viên duyệt mọi luật đề xuất, không có bước từ chối.

Độ trễ toàn tuyến. Độ trễ được đo trên 500 sự kiện lấy mẫu bước nhảy từ `build_stream()`, giữ nguyên tỉ lệ lành/tấn công thật thay vì ép cân bằng. Độ trễ trung bình toàn tuyến giảm từ **17.187,9 ms** (LLM đơn tầng) xuống **5.286,7 ms**, tức giảm **69,2%**, và chênh lệch có ý nghĩa thống kê theo kiểm định Mann-Whitney U ($p \approx 9 \times 10^{-57}$). Trung vị còn ấn tượng hơn nhiều: **0,88 ms** so với **17.174,7 ms**, tức khoảng **19.500 lần**—bởi sự kiện điển hình không bao giờ chạm tới LLM. Độ trễ trung bình theo từng chặng xác nhận đúng chênh lệch chi phí là động cơ của kiến trúc: **0,182 ms** tại Tầng 1, **0,924 ms** tại Cổng ML, và **22.785 ms** khi phải gọi LLM.

Một kết quả phải báo cáo dù bất lợi: **phân vị 95 của hệ hai tầng xấu hơn—25.829 ms** so với **21.434 ms** của cấu hình chỉ LLM. Nguyên nhân mang tính cấu trúc: sự kiện nào leo thang thì đã trả chi phí Tầng 1 và Cổng ML rồi mới trả tiếp chi phí LLM. Phần đuôi vì vậy thực sự chậm hơn, và lợi ích của kiến trúc tập trung ở trung vị chứ không trải đều. Báo trung bình và trung vị mà giấu phần đuôi là trình bày sai bản chất đánh đổi. Hai đặc điểm của chính lượt đo này phải đi kèm số của nó. Tỉ lệ xả tải trong lượt này chỉ đạt **76,8%**—116 trên 500 sự kiện chạm tới LLM, không phải 90,6% của Bảng 3—vì 500 mẫu lấy cách quãng không tích lũy đủ tiền sử theo địa chỉ để danh sách chặn phát huy tác dụng. Và bộ đệm RAG **trúng 0 trên 116 lượt tra**, nên hệ số tăng tốc $8,9\times$ nêu ở trên **không** nằm trong con số 5.286,7 ms. Về tài nguyên, luận văn báo cáo **số lời gọi LLM tránh được** (97.199 trên 99.717 sự kiện) thay vì tỉ lệ VRAM giải phóng, vì không có phép đo VRAM nào được thực hiện. Hình 7 trình bày trọn phân phối thay vì chỉ vài thống kê tóm tắt, và chính hình dạng của nó mang lập luận: đường hai tầng giải quyết khoảng ba phần tư số sự kiện dưới

hai mili-giây, rồi nằm ngang cho tới khi gặp lại đường đơn tầng ở phần đuôi.



Hình 7. Phân phối tích lũy độ trễ trên cùng 500 sự kiện. Lợi thế tập trung ở thân phân phối; ở phần đuôi thì hệ hai tầng chậm hơn. Sinh từ `latency_benchmark.json`. (Nguồn: Tác giả)

Đối chứng với các cấu hình khác. Để trả lời câu hỏi “nhanh hơn cái gì”, bốn cấu hình đối chứng được đo trên **cùng một mẫu con 150 sự kiện phân tầng** (Bảng 4), thay vì chép số headline từ công trình khác—phép so đó không hợp lệ vì khác tập dữ liệu và khác định nghĩa chỉ số.

Bảng 4. Thông lượng các cấu hình đối chứng trên cùng mẫu con 150 sự kiện phân tầng

Cấu hình đối chứng	Thông lượng
H1 — Chữ ký tĩnh, 30 họ WAF	11.129 sk/s
SENTINEL — Tầng 1 + Cổng ML	3.860 sk/s
H2 — LightGBM đơn tầng, ngưỡng phẳng	2.162 sk/s
H3 — LLM đơn tầng (cùng dữ liệu, mô hình và prompt)	0,19 sk/s

Đường tắt định của SENTINEL chạy nhanh hơn **trên 20.000 lần** so với việc đẩy mọi sự kiện lên mô hình ngôn ngữ (đo 20.531 lần). Chữ ký tĩnh còn nhanh hơn nữa, khoảng ba lần SENTINEL, và điều đó đúng như dự kiến—chúng không thực hiện phép suy luận thống kê hay mô hình nào. Chính thứ tự này là luận điểm kiến trúc gói trong một dòng: mỗi tầng tốn đúng phần chi phí của nó, và câu hỏi thiết kế là giải quyết được bao nhiêu lưu lượng trước khi chạm tầng đất. Hai trong số các con số trên không được cộng gộp: mức 0,19 sk/s đẩy từng sự kiện qua **toàn bộ tác tử Tầng 2** (797,9 s cho 150 sự kiện), còn mốc 17.187,9 ms

là **lời gọi mô hình trần** trên log thô, không giới hạn token và không lược đồ đầu ra. Hai con số mô tả hai thiết kế đơn tầng khác nhau, không phải một phép đo quy sang hai đơn vị. Cuối cùng, phép thử tải dồn trên luồng 99.717 sự kiện xác nhận cơ chế điều tiết ngược dựa trên độ trễ nhóm tiêu thụ giữ mức sử dụng RAM và VRAM ổn định, bảo đảm tính sẵn sàng liên tục.

Vì sao chọn những ngưỡng này. Chính sách bốn dải không phải một tối ưu đã tinh chỉnh mà là lựa chọn thận trọng có chủ ý, và phép quét điểm vận hành cho thấy cái giá của nó. Giữ nguyên dải leo thang và dải cảnh báo, ngưỡng chặn nằm trên một **vùng phẳng**: 0,70, 0,75, 0,80 và 0,85 cho chất lượng tổng hợp trùng khít, chỉ từ 0,90 trở lên độ bao phủ mới bắt đầu tụt. Chọn 0,85 vì thế mua được biên an toàn rộng nhất cho việc tự động chặn mà không mất gì đo được. Trên mọi cấu hình đã quét, **độ chính xác của phần tự chặn vẫn giữ 1,00**. Có một cấu hình tốt hơn về chỉ số tổng hợp—hạ dải leo thang xuống 0,50 thì MCC tăng—nhưng nó đạt được điều đó bằng cách leo thang ít đi, tức đánh đổi một con số đầu bảng lấy đúng sự thận trọng mà thiết kế này sinh ra để giữ.

Phát hiện cái chưa từng thấy: chỗ tầng thống kê bão hoà. Các bất thường tổng hợp được tìm ở biên độ từ 2σ tới 100σ trên bảy đặc trưng luồng hợp lệ (210 phép thử mỗi mức). Mọi phép thử ở mọi biên độ đều được **leo thang**, nên không có gì lọt qua trong im lặng. Tuy nhiên phần *nhận biết* thống kê thì chứng lại: tỉ lệ nhận biết tăng từ 19,52% ở 2σ lên **42,86%** ở 4σ rồi **dừng**, không đổi suốt 8σ , 20σ và 50σ , chỉ đạt 54,29% ở 100σ . Vượt quá khoảng bốn độ lệch chuẩn, làm bất thường lớn hơn không khiến nó dễ thấy hơn với tầng này—giới hạn nằm ở tập đặc trưng, không nằm ở ngưỡng. Hệ quả thực tiễn là hành vi mới lạ tới được Tầng 2 nhờ leo thang chứ không nhờ nhận dạng; đó là kiểu thất bại đúng đắn, nhưng không phải một tuyên bố về năng lực phát hiện.

4.3 RQ2 — Rào chắn An ninh AI và Toàn vẹn Pháp y

Mục này báo cáo **Mục tiêu 2 / RQ2. Mô hình đe dọa và giao ước đo**. RQ2 nêu nhiệm qua nền nhật ký là rủi ro đối kháng *điển hình*, không phải toàn bộ phạm vi. Vì vậy SENTINEL được đánh giá trước **hai mặt tấn công khác hẳn nhau về cấu trúc**. Mặt thứ

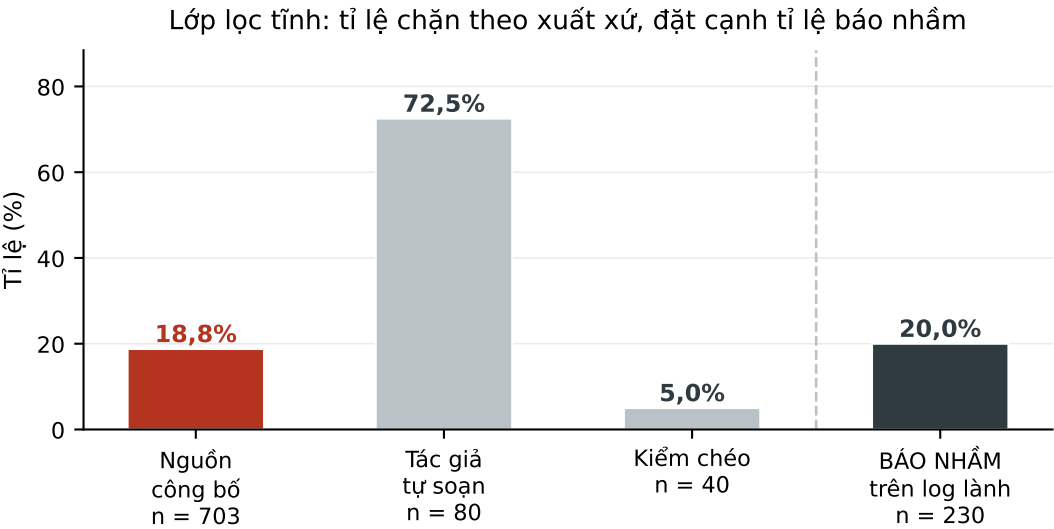
nhất tấn công **qua ngôn ngữ**: văn bản tiêm nhiễm và bẻ khoá nhúng trong các trường nhật ký, nhắm vào mô hình ngôn ngữ ở Tầng 2; kháng được nghĩa là chỉ thị nhúng không làm đổi hành động của tác tử. Mặt thứ hai tấn công **qua không gian đặc trưng**: bơm giá trị cực đoan hoặc vô cực vào thuộc tính luồng để ép Cổng ML LightGBM trả lời “lành”; kháng được nghĩa là mẫu đã bị bóp méo vẫn không bị lật thành lành. Một phòng tuyến chỉ phủ mặt thứ nhất là một phòng tuyến hẹp, vì hai tầng bị tấn công bằng hai cách hoàn toàn khác nhau.

Ba giao ước làm cho các tỉ lệ đọc được. Thứ nhất, phán quyết của lớp tính là phép HOẶC của **ba bộ dò tách rời**—khớp mẫu, vô hiệu hoá mã hoá, và bóc ký tự phân định—mỗi bộ ghi nhận riêng, để khi hỏng thì *định vị* được chứ không chỉ đếm được. Thứ hai, **đối chứng âm là bắt buộc**: cùng ba bộ dò đó chạy trên 230 nhật ký lành, bởi một lớp gán cờ mọi thứ cũng đạt “chặn 100%”, và một tỉ lệ chặn nêu mà thiếu tỉ lệ báo nhằm là con số không diễn giải được. Thứ ba, theo đúng Mục 4.1, mẫu từ nguồn công bố và mẫu do tác giả biên soạn được **chăm riêng, không bao giờ gộp vào một con số headline**. Bảng 5 nêu từng lớp rào chắn kèm mẫu số mà kết quả của nó được đo trên.

Tầng 1 trước tấn công qua ngôn ngữ. Trên nguồn công bố, lớp lọc tính chặn **18,8%**, và con số đó phải đọc kèm tỉ lệ báo nhằm **20,0%** trên nhật ký lành. Phân tích theo từng bộ dò định vị vấn đề chính xác: toàn bộ 46 ca báo nhằm đến từ lớp nhận dạng mã hoá, còn lớp khớp mẫu và lớp bóc phân định không sinh ca nào—một chỉ dẫn kỹ thuật về một lớp cụ thể, không phải bản án cho cả rào chắn. Cái giá của một ca báo nhằm cũng có giới hạn và phải nêu ra, vì con số 20% nghe rất đáng ngại nếu thiếu nó: cờ của lớp tính nâng mức cô lập và chú thích vào bản ghi, nhưng **không** loại bỏ sự kiện và không chặn nguồn. Vì vậy đây là tỉ lệ chú thích thừa, không phải tỉ lệ lưu lượng lành bị từ chối phục vụ. Phần mẫu tác giả biên soạn chặn tới 72,5%, cao hơn hẳn số của nguồn công bố, và khoảng cách đó được giải thích chứ không được bào chữa: 45 trong 80 mẫu ấy là ca vượt mã hoá, mà lớp vô hiệu hoá mã hoá được dựng ra đúng để trị chúng. Trích con số gộp 23,3% sẽ tăng bóc hệ thống bằng cách đếm cả những mẫu được viết ra khi đã biết trước cơ chế phòng thủ; **18,8% mới là con số luận văn đứng sau**. Hình 8 đặt cả bốn tỉ lệ lên cùng một trục, để không ai đọc được tỉ lệ chặn mà bỏ qua đối chứng âm của nó.

Bảng 5. Các lớp rào chắn, mẫu số phép đo và kết quả

Lớp rào chắn	Mẫu số	Kết quả
Tầng 1 — tấn công qua ngôn ngữ		
Lớp lọc tĩnh, nguồn công bố theo bộ dò: khớp mẫu / mã hoá / phân định	703 mẫu 703	132 → 18,8% 114 / 29 / 0
Lớp lọc tĩnh, mẫu tác giả biên soạn	80 mẫu	58 → 72,5%
Lớp lọc tĩnh, tập kiểm chéo	40 mẫu	2 → 5,0%
Lớp lọc tĩnh — báo nhầm trên nhật ký lành trong đó: lớp nhận dạng mã hoá	230 nhật ký lành 46/46	46 → 20,0% toàn bộ
Tầng 1 — tấn công qua không gian đặc trưng		
Cổng ML — né tránh, chế độ khó (bóp méo mọi đặc trưng; 13 ca bị lật, CI95 97,86–99,27)	1.036 ca tấn công đã bắt	1.023 → 98,75%
Cổng ML — chế độ một đặc trưng (∞ / cực đoan)	1.036 × 2	100% cả hai
Cổng ML — từ chối phán quyết khi đầu vào biến dạng	4.236 sự kiện	116 → leo thang
Tầng 2 — bảo chứng cấu trúc		
Đóng gói dữ liệu phân định bằng nonce	678 mẫu khó, độ phủ 100%	678 → 100%
Kiểm lược đồ khi ép hồng cổ máy suy luận	1 lần ép hồng	AWAIT_HITL, không sụp hành động trùng khớp 0 mẫu đối phán quyết xấu nhất 1.655
Tắt định (cùng hạt giống, 5 lượt)	5 lượt	
Đổi riêng hạt giống	10 mẫu	
Chống tràn ngữ cảnh	cửa sổ 16.384 token, ngân sách 4.000	
Toàn vẹn pháp y		
HMAC — ba kiểu giả mạo cốt lõi	30 lượt mỗi kiểu	100%
HMAC — đối chứng âm (chuỗi nguyên vẹn)	450 bản ghi	không báo động giả
HMAC — cắt đuôi chuỗi	—	0% — không phát hiện được



Hình 8. Lớp lọc tĩnh: tỉ lệ chặn theo xuất xứ đặt cạnh tỉ lệ báo nhầm trên log lành. Sinh từ `robustness_results.json` và `adversarial_negative_results.json`. (Nguồn: Tác giả)

Tầng 1 trước tấn công qua không gian đặc trưng. Cổng ML kẹp Z -score trong $\pm 8\sigma$, điền giá trị thiếu bằng trung bình baseline, và từ chối phán quyết khi tỉ lệ đặc trưng biến dạng vượt 30%. Ở **chế độ khó**, nơi *toàn bộ* đặc trưng của một ca tấn công đã bị bắt đúng bị đẩy tới cực trị, **98,75%** số mẫu vẫn kháng được (1.023/1.036; CI95 97,86–99,27), với 13 ca bị lật thành lành. Hai chế độ một-đặc-trưng đạt 100%, và luận văn trích chế độ khó chứ không trích trung bình ba chế độ, vì gộp thêm hai chế độ bảo hoà một cách tầm thường sẽ thổi con số vượt quá mức mà phòng tuyến thực sự chứng minh được. Việc từ chối phán quyết được tính là kết quả của rào chắn chứ không phải thất bại: 116 sự kiện được đẩy lên thay vì đoán bừa, bởi một câu trả lời sai kèm độ tin cậy cao sẽ khiến hệ tự hành động mà không ai kiểm lại.

Tầng 2 và khác biệt về bản chất. Lớp tính là bộ lọc rẻ đặt phía trước; bảo chứng an ninh đến từ **Đóng gói Dữ liệu Phân định**, vốn mang tính cấu trúc—nội dung nằm trong vùng bọc nonce được xử lý như văn bản thụ động *bất kể nó nói gì*. Cơ chế này được đo trên **toàn bộ 678 mẫu thuộc bảy nhóm mà lớp tính không hấp thụ được**, ở **độ phủ 100%** của tập đó. Đây là siêu tập của 543 mẫu thật sự lọt qua lớp tính trong các nhóm ấy, nên phép thử chặt hơn mức cần chứ không phải chọn mẫu dễ; Tầng 2 kháng được **678/678**, trong đó 676 ca (99,7%) sinh một lời gọi mô hình ngôn ngữ độc lập, hai ca gộp về cùng một dấu vân cache. Khác biệt về bản chất nằm ở đây: một bộ phân loại chặn $x\%$ luôn để lọt $(100 - x)\%$ và suy giảm trước biến thể mới, trong khi bảo chứng cấu trúc không phụ thuộc vào việc nhận dạng được nội dung độc hại hay không. Con số 18,8% vì vậy **không mâu thuẫn** với luận điểm—nó định lượng chính xác khối lượng công việc mà lớp cấu trúc phải gánh. Hai phép kiểm độ ổn định củng cố mọi số đo phụ thuộc LLM trong chương này, và mỗi phép phải nêu kèm giới hạn của nó. Với cùng một hạt giống, tác tử đưa ra **hành động trùng khớp hoàn toàn** qua năm lượt—nhưng chỉ trên **một** mẫu. Đối riêng hạt giống trên mười mẫu **không làm đổi phán quyết nào**; ở $n = 10$, điều đó chỉ chặn được tỉ lệ lật ở mức **0,2775** (cận trên KTC 95%), và cả mười mẫu đều ra `AWAIT_HITL` ở mọi hạt giống, tức phép đo bảo hoà ở một hành động duy nhất nên phân giải được rất ít. Hai phép kiểm này vì vậy khiến khả năng “chênh lệch giữa các cấu hình chỉ là nhiều bộ giải mã” trở nên *khó xảy ra*—chứ không loại trừ được nó. Khi ép cỗ máy suy luận hỏng, hệ suy biến về

AWAIT_HITL thay vì sụp đổ hoặc rơi về hành động dễ dãi.

Phát hiện giả mạo bằng cách nào. Phép kiểm tính lại toàn chuỗi từ bản ghi gốc theo $H_i = \text{HMAC}(D_i \parallel H_{i-1}, K)$. Vì mỗi mắt xích ăn vào hash của mắt trước, một byte bị đổi ở D_j làm hỏng *mọi* mắt xích từ j trở đi, nên việc phát hiện có **định vị** chứ không chỉ báo “có gì đó đã đổi”. Ba kiểu giả mạo cốt lõi ánh xạ đúng vào ba cách phá tính liên tục: **sửa nội dung** làm hash tính lại tại j không khớp hash đã lưu; **chèn bản ghi giả** tạo ra một mắt xích không có tiền nhiệm hợp lệ để trở về; **xoá bản ghi giữa** khiến H_{j+1} trở tới một hash không còn tồn tại. Cả ba đều bị phát hiện 30/30 lượt, và đối chứng âm trên 450 bản ghi nguyên vẹn không sinh báo động giả nào. Phép đo chạy với khoá nạp từ biến môi trường, không phải khoá mặc định trong mã nguồn—một khoá lộ trong mã cho phép dựng lại cả chuỗi từ đầu và làm mọi tỉ lệ ở trên mất giá trị. Luận văn chủ động nêu điểm mù: **cắt cụt đuôi chuỗi không thể phát hiện được**, đây là tính chất nguyên lý của log-chaining, vì xoá các bản ghi cuối không để lại mắt xích nào phía sau để đối chiếu. Cách khắc phục là neo giá trị hash ra ngoài hệ thống theo chu kỳ.

Những rào chắn không quy về một tỉ lệ. Nhiều cơ chế bảo vệ các đường mà không tỉ lệ chặn nào đo được. RAG_Sanitizer bảo vệ kho tri thức ở cả hai thời điểm—lúc nạp thì chuẩn hoá NFKC chống homoglyph, xoá ký tự điều khiển và ký tự rộng-không, lược thẻ HTML/JS cùng ảnh và liên kết Markdown; lúc truy xuất thì vô hiệu hoá các chỉ thị mệnh lệnh nhúng trong tài liệu. Thiết kế của nó mang một bài học đo được: một bản trước đó khớp cụm bị chặn ở bất kỳ vị trí nào trong câu, nên đã viết đề lên văn xuôi an ninh hợp lệ, vô hiệu hoá nhằm bốn mục kỹ thuật di chuyển ngang (T1090, T1021, T1021.001, T1553.001) mà chính các kịch bản APT của luận văn cần tới. Việc giới hạn khớp vào **vị trí mệnh lệnh** đã triệt tiêu hiện tượng này, và phép kiểm lại trên kho tri thức 433 mục hiện tại cho **không có** ca vô hiệu hoá nhằm nào—chính là kỷ luật “chặn phải đọc kèm báo nhằm” áp cho một lớp không công bố tỉ lệ nào. FeedbackValidator đóng lại lỗ hổng mà vòng phản hồi Tầng 2 về Tầng 1 ở Mục 4.2 mở ra: luật được thăng cấp từ phán quyết phải qua danh sách trường cho phép, phép kiểm mẫu và chặn dải điểm, vì một cơ chế học từ phán quyết cũng là một cơ chế đầu độc luật Tầng 1. DecisionValidator áp lược đồ đầu ra, cứu hồi trường sai định dạng bằng biểu thức chính quy, và đòi **Tầng 1 đồng**

thuận trước mọi lệnh tự động chặn. Một bộ dò vòng lặp giới hạn số lần thăm mỗi nút ở mười lượt để tác tử không quẩn vòng đốt thời gian GPU, và một bộ làm sạch đầu ra bóc các khối base64 và thập lục phân trước khi bản ghi tới cơ sở dữ liệu hay bảng điều khiển, khoá đường phát tán ngược qua giao diện chuyên gia.

Vị trí trường, đo tách riêng. Vì cơ chế đóng gói nonce bọc **theo từng trường**, vị trí trường quyết định payload nằm trong hay ngoài vùng bọc—một tính chất mà không con số gộp nào kiểm được, bởi các nhóm còn lại đều đặt payload vào cùng một trường. Tập `field_injection` gồm 100 mẫu công bố rải payload qua bốn vị trí: URI 24, User-Agent 23, message 30, payload 23. Lớp tính chỉ chặn 12/100, đúng như dự kiến với tiềm năng bằng ngôn ngữ đời thường không mang mã hoá và không mang ký tự phân định. Cho chạy qua Tầng 2 ở **độ phủ 100%**, cả 100 mẫu đều kháng được, với phán quyết phân bố 73 BLOCK_IP và 27 ALERT, không ca nào tụt về hành động dễ dãi.

Tuyên bố theo từng vị trí trường phải đo lại lần thứ hai, và lý do mới là điều đáng học.

Ở lượt chạy đầu, con số gộp trông đã đủ thuyết phục và phân tách theo vị trí trông đồng đều—nhưng 100 mẫu chỉ sinh ra **79 phán quyết độc lập của mô hình ngôn ngữ**. Khoá cache lớp hai dựng từ `message`, `payload` và `uri` mà bỏ sót `user_agent`, nên 23 mẫu tiêm vào User-Agent gộp về **hai** dấu vân: hai phán quyết phát lại hai mươi một lần, đúng ở cột mà thí nghiệm sinh ra để kiểm. Ở đây, một khiếm khuyết của dụng cụ đo và một mặt tấn công đầu độc cache đang sống là cùng một khiếm khuyết, bởi trong vận hành kẻ tấn công cũng có thể đổi riêng một trường vắng mặt trong khoá và nhận lại phán quyết đã lưu. Mở rộng khoá để phủ mọi trường tầng ứng dụng đưa số dấu vân về đúng 100, và thí nghiệm được chạy lại trên nền đó.

Kết quả đo lại **đồng đều trên cả bốn vị trí**—24/24, 23/23, 30/30 và 23/23—lần này dựa trên một trăm phán quyết độc lập chứ không phải bảy mươi chín. Chính sự đồng đều mới là phát hiện, không phải con số tổng: nếu cơ chế bọc chỉ áp cho một số trường mà bỏ sót trường khác, các vị trí không được bọc sẽ lộ ra ở đây thành một lỗ hổng. Kết quả này báo tách khỏi con số 678 vì nó trả lời một câu hỏi khác, và giai thoại trên được kể ra vì con số sau khi sửa *trùng khít* con số trước khi sửa—đó chính là lý do mẫu số phải được kiểm chứ

không được mặc định là đúng.

4.4 RQ3 — Suy luận Có trạng thái và Quy kết Kỹ thuật

Mục này báo cáo **Mục tiêu 3 / RQ3**. RQ3 gồm bốn vế: quy kết kỹ thuật ATT&CK, truy xuất tri thức, báo cáo minh bạch, và giảm tải người. Mỗi vế được đo riêng dưới đây, vì chúng hổng vì những lý do khác nhau và một điểm số gộp sẽ che mất điều đó.

Quy kết: thêm tầng suy luận thì kết quả xấu đi. Quy kết được đo hai lần trên **cùng một dân số**—500 mẫu tầng payload lấy từ `ground_truth.json` sau khi loại mẫu tự biên soạn, gồm 250 mẫu có nhãn kỹ thuật và 250 mẫu lành, nguồn CSIC 2010. Lượt thứ nhất chỉ chạy **truy xuất**: RRF hợp nhất quyết định mã kỹ thuật, không có mô hình ngôn ngữ tham gia. Lượt thứ hai chạy **toàn tuyến tác tử**. Tỷ lệ khớp chính xác giảm từ **80,0%** xuống **68,0%**, khớp mức chiến thuật giảm từ 80,0% xuống 70,4%, trong khi độ trễ trung vị tăng từ **0,54 ms** lên **13.293 ms**. Tầng suy luận tiêu tốn thêm bốn bậc độ lớn về thời gian và trả lại độ chính xác *thấp hơn* mười hai điểm so với chính tầng truy xuất mà nó được thêm vào để cải thiện.

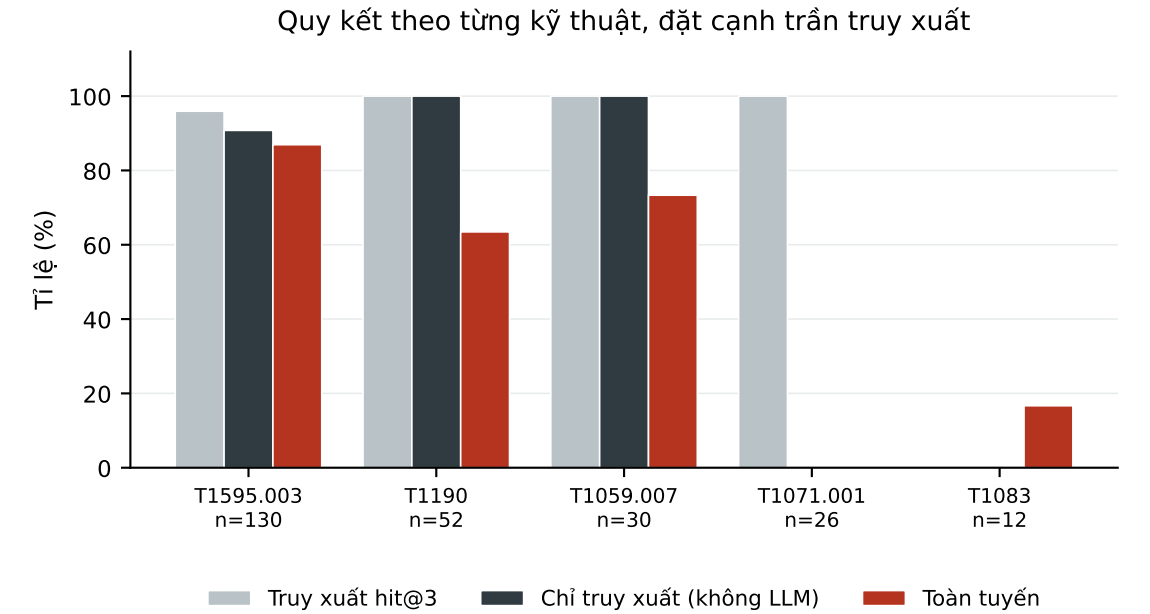
Phần mất đi giải thích được chứ không phải bào chữa. Trong 30 mẫu mất, tối đa **22** mẫu là những ca rào chắn neo bằng chứng ép phán quyết về N/A vì mã kỹ thuật mô hình đề xuất không hiện diện trong tài liệu truy xuất của chính lô đó. Đây là một đánh đổi có chủ ý chứ không phải trục trặc: hệ đổi độ chính xác quy kết lấy bảo chứng rằng nó không bao giờ hành động dựa trên một mã không có bằng chứng đỡ. Mọi con số ở đây cũng phải đọc so với một cái sàn chứ không so với 0—T1595.003 chiếm 130 trong 250 mẫu có nhãn, nên một hệ luôn trả lời đúng mã đó đã đạt **52%**.

Bảng 6 làm được điều mà con số gộp không làm được: nó **định vị tầng nào hổng**. Với T1083, bộ truy xuất không bao giờ trả về đúng tài liệu, nên lỗi nằm ở kho tri thức và không thành phần nào phía sau cứu được. Với T1071.001, bộ truy xuất trả đúng tài liệu ở mọi lượt mà quy kết vẫn bằng không, nên lỗi nằm ở bộ ánh xạ. Hai lỗi cần hai cách sửa khác nhau, và một con số 68,0% đúng một mình thì không kê được toa nào. Hình 9 vẽ lại

Bảng 6. Quy kết theo từng kỹ thuật trên lát 500 mẫu tầng payload, kèm trần truy xuất của cùng bộ truy vấn. Quy kết chấm trên cả 250 mẫu có nhãn; truy xuất chấm trên 243 mẫu mà Tầng 1 có leo thang, và ở mức kỹ thuật cha—hai mẫu số vì vậy lệch nhau đôi chút và không thay thế cho nhau được.

Kỹ thuật ATT&CK	<i>n</i>	Truy xuất hit@3	Chỉ truy xuất	Toàn tuyến
T1190 — Khai thác ứng dụng công khai	52	1,00	100,0%	63,5%
T1059.007 — Thực thi JavaScript	30	1,00	100,0%	73,3%
T1595.003 — Quét theo từ điển	130	0,96	90,8%	86,9%
T1083 — Dò tệp và thư mục	12	0,00	0,0%	16,7%
T1071.001 — Giao thức web	26	1,00	0,0%	0,0%
Toàn bộ kỹ thuật	250	0,93	80,0%	68,0%

đúng ba dãy số đó.



Hình 9. Quy kết theo từng kỹ thuật đặt cạnh trần truy xuất. Chỗ nào cột nhạt cao mà hai cột đậm bằng không thì lỗi ở bộ ánh xạ; chỗ nào cột nhạt bằng không thì lỗi ở kho tri thức. Sinh từ ba tệp kết quả RQ3. (Nguồn: Tác giả)

Truy xuất tri thức và trần của nó. Trên cùng lát payload—243 truy vấn, đã loại bảy ca Tầng 1 không leo thang—Dual-RAG đạt **Recall@3 = 0,930** (KTC 95% 0,891–0,956), MRR 0,803, và hạng trung vị bằng 1 khi tìm thấy tài liệu đúng. Đó chính là trần thật của các con số quy kết ở trên, và nó nằm thoải mái phía trên chúng, nên mạch lập luận khép kín: truy xuất không phải là thứ chặn mức 80,0%. Nửa bất lợi phải nêu rõ ràng không kém. Do trên toàn bộ tập `ground_truth` gồm 1.305 truy vấn, Recall@3 sụp còn **0,385**, vì

các mẫu chỉ có tầng luồng chi phối dân số đó và không mang chữ tầng ứng dụng nào để khớp—T1110 đạt hit@3 **0,00** trên 236 truy vấn. Hai con số mô tả **hai dân số khác nhau** và không bao giờ được đem 0,385 đặt cạnh 80,0%; so như vậy là vi phạm chính nguyên tắc đã đặt ra ở Mục 4.1.

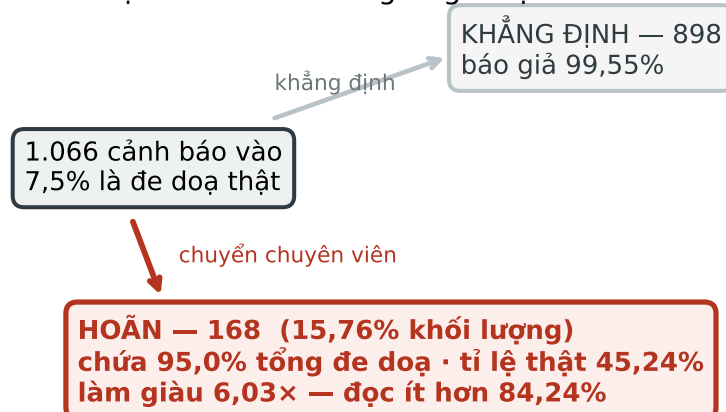
Rào chắn neo, đo từ bản ghi thực thi. Rào chắn neo bằng chứng (Mục 3.5) buộc mọi mã kỹ thuật công bố phải hiện diện trong tài liệu truy xuất của chính lô đó; vi phạm bị ép về N/A và chuyển Awaiting_HITL. Kiểm chứng cơ chế này đòi hỏi thận trọng, vì nếu chỉ đọc phán quyết cuối thì *bất kỳ* lá chắn nào cũng đạt không ảo giác—kể cả một lá chắn chẳng làm gì. Phép đo vì vậy chạy trên bản ghi thực thi có lưu hành động *trước* và *sau* lá chắn: **1.566 lô**, trong đó 1.421 lô có khẳng định một kỹ thuật. Kết quả là **không** một khẳng định nào thiếu neo (0 trên 1.421), và vẫn bằng không kể cả khi nói tới kỹ thuật cha. Bằng chứng cho thấy lá chắn thực sự làm việc nằm ở số lần kích hoạt: nó nổ **145 lần (9,26%)**, và **76** lần trong số đó đã hạ BLOCK_IP xuống Awaiting_HITL—nghĩa là **76 lệnh chặn IP vĩnh viễn tự động đã bị ngăn lại** vì lời biện giải không neo được vào bằng chứng. Cả 76 ca đều xuất phát từ mã do chính mô hình đề xuất; 69 lần kích hoạt còn lại bắt các mã do bộ ánh xạ tự suy. Những mã bị từ chối nhiều nhất là T1218 (27), T1083 (24), T1071.001 (16) và T1190 (14). Một giới hạn phải nêu chủ động: điểm số này dùng thước **chặt**—mã phải nằm trong danh sách ID tài liệu đã truy xuất—trong khi lá chắn đang vận hành khớp bằng biểu thức chính quy trên toàn văn ngữ cảnh, nên số không ở đây là **cận trên** của số ca lá chắn bỏ lọt chứ không phải con số chính xác.

Phân loại phần việc chuyển tới con người. Đây là vế trả lời RQ3 trực tiếp nhất, và nó cho ra kết quả tiêu cực nhất của cả chương. Tầng 1 đẩy lên **1.066 cảnh báo**, trong đó chỉ **80 ca (7,5%) là đe dọa thật**; dân số bị chi phối bởi 910 yêu cầu CSIC lành, bên cạnh 75 mẫu cicits, 76 mẫu cicits_max, 4 mẫu zero-day và 1 mẫu đối kháng. Xét như một bộ phân loại nhị phân trên hàng đợi đó, mô hình ngôn ngữ **vô giá trị**: nó gắn cờ cả 1.066 ca, không hạ cấp **ca nào** trong 986 cảnh báo giả, nên đạt **MCC 0,0**, specificity **0,0** và Balanced Accuracy **0,5**. Trong phần nó chủ động khẳng định, tỉ lệ báo giả là **99,55%** (894 trên 898; KTC 95% 98,86–99,83). Độ tự tin của nó không chỉ vô nghĩa mà còn gây lạc hướng—tự tin trung bình khi gắn cờ là **0,846** trong khi tỉ lệ thật là 7,5%, sai số hiệu chuẩn kỳ vọng

0,803, và 900 phán quyết tự tin nhất thì đúng **không** lần nào.

Giá trị nằm ở chỗ khác, ở đúng cái kênh mà cách đóng khung nhị phân bỏ qua. Tác tử hoãn **168 cảnh báo** sang `AWAIT_HITL`—**15,76%** lượng đầu vào—và hàng đợi đó chứa **76 trong 80 đe dọa thật (95,0%)**, với mật độ cảnh báo thật **45,24%** so với 7,5% ở đầu vào. Đó là mức **làm giàu 6,03×**: chuyên viên chỉ xem hàng đợi hoãn sẽ đọc ít hơn **84,24%** khối lượng mà vẫn thấy 95,0% đe dọa thật. Kết luận vận hành theo ngay sau đó, và được nêu như một phát hiện chứ không phải một lời biện hộ: mô hình này dùng được như **bộ định tuyến phân loại** và không dùng được như bộ tự khẳng định. MCC 0,0 cũng không mâu thuẫn với RQ3 như đã đặt, vì RQ3 hỏi về việc giảm và *phân loại chính xác* phần việc cần người, không hỏi về phán quyết đúng trên mọi cảnh báo—và vì 910 trong 1.066 ca leo thang là lưu lượng CSIC lành, con số này còn phản ánh chất lượng quyết định leo thang của Tầng 1 chứ không riêng của tác tử. Để đủ mẫu số: 68 trong 1.066 lô được phục vụ từ cache, còn lại **998** lời gọi mô hình ngôn ngữ độc lập. Hình 10 tóm tắt cả hai kênh trên cùng một sơ đồ.

Phân loại cảnh báo ở Tầng 2: giá trị nằm ở kênh hoãn, không ở phán quyết



Hình 10. Phân loại cảnh báo ở Tầng 2. Kênh khẳng định gần như toàn báo giả; kênh hoãn mới là nơi đe dọa thật dồn về. Sinh từ `tier2_decision_results.json`. (Nguồn: Tác giả)

Chất lượng lập luận. Lời biện giải của tác tử được chấm bởi **trọng tài khác họ mô hình** (Meta-Llama-3-8B-Instruct chấm Foundation-Sec-8B-Instruct) trên thang 1–5 theo bốn trục của khung đánh giá sinh có tăng cường truy xuất RAGAS [37], theo đúng khuyến nghị nhằm loại bỏ Thiên kiến Tự đề cao [38]. Lướt đo phủ toàn bộ **1.052** sự kiện leo thang và sạch ở đúng khía cạnh có ý nghĩa cho việc diễn giải: **không phán quyết nào thiếu**

trường bắt buộc, và 71 ca không trả về mã kỹ thuật là **từ chối có chủ ý** do rào chắn neo cưỡng chế chứ không phải lỗi phân tích cú pháp. Kết quả bốn trục: độ chính xác ngữ cảnh **2,54**; độ liên quan câu trả lời **4,52**; độ trung thành với ngữ cảnh **3,96**; độ bao phủ ngữ cảnh **4,11**; trung bình **3,78/5,0**.

Hai kết quả bất lợi cho hệ và được báo cáo đúng như vậy. **Độ chính xác ngữ cảnh 2,54 là trục yếu nhất**, củng cố chẩn đoán về truy xuất ở trên: tập tài liệu trả về thường mang theo những mục không liên quan tới sự kiện đang xét, và nút thất vì vậy nằm ở tầng truy xuất chứ không ở tầng sinh. Nghiêm trọng hơn, **chỉ số neo bằng chứng chỉ đạt 11,2%** (KTC 95% 9,5–13,3), trung bình **0,2** trích dẫn kiểm chứng được trên mỗi lời biện giải—tức khoảng chín trên mười lời biện giải không dẫn ra một giá trị log nào có thể đối chiếu ngược lại bản ghi. Đây là khoảng cách rõ nét nhất trong kiến trúc giữa cái được *bảo chứng* và cái được *tự nguyện đưa ra*: rào chắn neo chứng minh được rằng mã ATT&CK đã khẳng định có tài liệu truy xuất đỡ lưng, nhưng không có gì buộc phần văn xuôi xung quanh phải trích dẫn đúng những giá trị trường đã dẫn tới kết luận đó. Về báo cáo pháp y minh bạch của RQ3 vì vậy mới đạt được một phần, và bít khoảng cách này là việc ràng buộc định dạng lời biện giải chứ không phải việc cải thiện mô hình.

Bóc tách thành phần: mỗi tầng thực sự đóng góp gì. Phép so cấu hình khép lại vòng nối giữa thiết kế ở Chương 3 và kết quả báo cáo tại đây. Sáu cấu hình được chấm trên `ground_truth.json`, và việc chọn thước đo phải được biện minh trước khi đọc số. Cách chấm nhị phân—hệ có gắn cờ sự kiện hay không—**không dùng được** trên tập này: tỉ lệ tấn công là 86,9%, nên mọi cấu hình đều cho điểm sát con số đó và phép so sụp đổ. Trước đây mọi cấu hình trông y hệt nhau chính vì lý do này. Chấm theo **hành động cuối cùng**—phán quyết phát ra có khớp phán quyết kỳ vọng hay không, trên bốn giá trị `BLOCK_IP`, `ALERT`, `LOG` và `AWAIT_HITL`—khôi phục lại khả năng phân biệt mà thước nhị phân đã phá mất. Việc đổi thước được báo cáo ở đây thay vì lặng lẽ bỏ qua, vì một thước đo chọn sau khi đã thấy kết quả là thước đáng ngờ; căn cứ ở đây là thước nhị phân suy biến trên phân bố này, không phải vì nó cho con số khó coi.

Bảng 7 trình bày sáu cấu hình. Ba phát hiện rút ra, và cái thứ hai mới là cái đáng kể. Thứ

Bảng 7. Bóc tách thành phần chấm theo hành động cuối, đã loại 50 mẫu tác giả tự soạn. Cấu hình A và F chấm trên toàn bộ 1.700 mẫu còn lại; B–E chấm trên một lát 300 mẫu riêng nên **không** so trực tiếp với A và F được. Sinh từ `ablation_action_scores.json`.

Cấu hình	<i>n</i>	Đúng h.động (KTC 95%)	Tự quyết	Hoãn	C.xác tự quyết
A — Chỉ Tầng 1, không LLM	1.700	28,29% (26,20–30,48)	41,00%	0,00%	69,01%
F — Hệ hai tầng đầy đủ	1.700	35,35% (33,12–37,66)	55,24%	44,76%	57,72%
B — LLM, không truy xuất	300	34,00% (28,87–39,53)	69,67%	30,33%	45,93%
C — + truy xuất dày	300	41,33% (35,90–46,98)	98,67%	1,33%	41,89%
D — + truy xuất thưa	300	41,33% (35,90–46,98)	98,67%	1,33%	41,89%
E — + hợp nhất hạng	300	41,33% (35,90–46,98)	98,67%	1,33%	41,89%

nhất, tăng suy luận xứng đáng với chi phí của nó: hệ đầy đủ đạt **35,35%** độ chính xác hành động so với **28,29%** của riêng Tầng 1, và hai khoảng tin cậy không chồng lấn, nên chênh lệch không phải nhiễu lấy mẫu. Thứ hai, và giàu thông tin hơn con số đầu bảng, **sự đánh đổi đảo chiều**. Riêng Tầng 1 lại là bên phán quyết *đáng tin hơn* mỗi khi nó chịu quyết—**69,01%** độ chính xác tự quyết so với **57,72%**—nhưng nó chỉ chịu quyết trên 41,00% số sự kiện và bỏ ngỏ **59,00%**, đẩy chúng lên một tầng mà ở cấu hình A vốn không tồn tại. Hệ đầy đủ không bỏ ngỏ ca nào; nó chuyển toàn bộ phần tồn đọng đó thành **44,76%** ca hoãn tường minh cho chuyên viên. Hai tầng vì vậy khác nhau không nhiều ở chỗ suy nghĩ giỏi đến đâu, mà ở **cách hành xử khi không biết**—đúng thuộc tính mà Mục 4.4 đã đo từ chiều ngược lại qua kênh hoãn.

Thứ ba, một kết quả rõ ràng được báo cáo đúng như vậy: **C, D và E trùng khít tới từng chữ số**. Thêm truy xuất thưa vào truy xuất dày, rồi hợp nhất hai bảng hạng, không làm đổi một phán quyết nào trên lát này. Đây là giới hạn của thiết kế bóc tách chứ không phải bằng chứng rằng bậc thang truy xuất là vô dụng—cả ba cấu hình chỉ gọi mô hình ngôn ngữ với những sự kiện mà Tầng 1 leo thang, nên đại đa số lát mẫu rơi về cùng một `tier1_verdict` bất kể bộ truy xuất trả về gì. Muốn cô lập đóng góp của phép hợp nhất hạng thì phải đánh giá riêng trên các sự kiện đã leo thang—đúng thứ mà phép đo truy xuất ở trên cung cấp còn phép bóc tách này thì không.

Tương quan đa giai đoạn, ở đúng quy mô mà bằng chứng cho phép. Khả năng tương quan có trạng thái xuyên suốt một chiến dịch được thử trên chín chuỗi DAPT2020: cả **3/3**

chuỗi đa ngày thật đều được dựng lại, và không một chuỗi nào trong **4** chuỗi đa ngày lành kích hoạt cảnh báo chiến dịch giả. Kết quả nêu ra cho đầy đủ và không tuyên bố điều gì: với ba ca dương, khoảng tin cậy 95% của độ bao phủ trải từ **0,44 đến 1,00**, tức tương thích với cả một hệ chạy đúng lẫn một hệ gặp may. Nhất quán với Mục 1.2, tương quan đa giai đoạn vẫn là năng lực ở mức minh chứng khả thi và được chuyển sang hướng phát triển chứ không tính là đóng góp.

Phân công kiến trúc giữa hai tầng. Một kết quả tưởng như tiêu cực lại xác nhận thiết kế: trên nhóm mẫu ngoài NetFlow (tấn công web CSIC, zero-day, DAPT), Cổng ML chỉ đạt Recall **11,1%**, và 305 trong 336 ca trượt của toàn tập nằm gọn trong nhóm này. Nguyên nhân mang tính kiến trúc chứ không phải lỗi—Cổng ML học trên **đặc trưng luồng**, trong khi tấn công web nằm ở **payload**, vốn là phần việc của Tầng 2 và tập chữ ký. Hệ quả phương pháp luận là Recall tổng 0,755 đang trộn hai quần thể không cộng được và phải báo tách bạch. Liên quan tới điều đó, như đã nêu ở Mục 3.4, tỉ lệ chuyển chuyên gia **không** phải chỉ số cần tối thiểu hoá: một kiến trúc tuyên bố tỉ lệ chuyển-người bằng 0 trên mọi tình huống là kiến trúc đã bỏ mất rào chắn cuối cùng.

Chương 5

Kết luận

Một Trung tâm Điều hành An ninh hiếm khi thất bại vì không phát hiện được cuộc xâm nhập. Nó thất bại ở bước ngay sau phát hiện, nơi một số hữu hạn chuyên viên phải quyết định xem trong dòng cảnh báo gần như vô hạn kia, cái nào đáng để họ dừng lại xem xét. Mô hình ngôn ngữ lớn là công nghệ đầu tiên đọc được một sự kiện trong ngữ cảnh của nó và giải thích bằng thứ ngôn ngữ con người hành động được, nhưng đặt một mô hình như vậy vào giữa luồng dữ liệu vận hành lại phát sinh chi phí về thời gian, về niềm tin và về chủ quyền dữ liệu—những thứ mà không con số độ chính xác đầu bảng nào trả lời thay được. Luận văn đặt câu hỏi liệu có thể có được năng lực đó mà không phải trả đủ cái giá của nó, và trả lời bằng cách dựng SENTINEL—kiến trúc hai tầng đặt quyết định rẽ trước quyết định dứt, vận hành trơn vẹn trên một máy trạm cục bộ—rồi *đo* nó thay vì mô tả nó. Ba kết quả đỡ lấy luận điểm ấy.

Bài toán kinh tế của phân tầng đứng vững, và đứng vững như một quy luật chứ không phải một con số. Tầng 1 cùng Cổng Học máy giải quyết **90,6%** luồng benchmark vốn được nạp tỉ lệ tấn công cao gấp hơn ba lần thực tế, và **97,5%** luồng có tỉ lệ tấn công gần với thực tế, cả hai trường hợp đều không tốn một lời gọi mô hình ngôn ngữ nào. Vì sự kiện điển hình không bao giờ chạm tới mô hình, độ trễ toàn tuyến ở mức trung vị giảm còn **0,88 ms** so với **17.174,7 ms** của đường đơn tầng. Kết quả phương pháp luận còn quan trọng hơn cả hai con số đó: tỉ lệ xả tải phân tích tuyến tính thành một hệ số cho ca lạnh và một hệ số cho ca tấn công, tức nó là **hàm của tỉ lệ tấn công nền của luồng chứ không phải hằng số của hệ thống**—tính chất cho phép chuyển phép đo sang môi trường khác, điều mà một tỉ lệ phần trăm đứng một mình không làm được.

Bảo chứng an ninh mang tính cấu trúc, nên nó không suy giảm theo thời gian. Cơ chế

Đóng gói Dữ liệu Phân định xử lý nội dung nằm trong ranh giới nonce sinh theo từng lô như văn bản thụ động, bất kể nội dung đó nói gì, và đã kháng được **toàn bộ 678** mẫu đối kháng thuộc các nhóm mà lớp lọc tính giá rẻ không hấp thụ được—đúng những nhóm chứa các đòn tấn công mà lớp lọc ấy hoàn toàn mù. Đây là một loại bảo đảm khác hẳn với một bộ phân loại chặn được $x\%$ rồi để lọt phần còn lại trước mọi cách diễn đạt mới. Song song, chuỗi HMAC-SHA256 phát hiện **100%** cả ba kiểu giả mạo cốt lõi và không báo động giả lần nào trên chuỗi đối chứng nguyên vẹn, niêm phong hồ sơ pháp y bằng tính toàn vẹn và khả năng phát hiện giả mạo.

Kiểm soát ảo giác được chuyển từ một kỳ vọng thành một ràng buộc kiểm chứng được. Mọi mã ATT&CK hệ công bố đều phải hiện diện trong tài liệu truy xuất của chính lô đó; trên **1.421** phán quyết có khẳng định kỹ thuật, **không** một khẳng định nào thiếu neo. Rào chắn đạt được điều đó mà không hề nằm im—nó kích hoạt trên 9,26% số lô và trong **76** lần đã ngăn một lệnh chặn IP vĩnh viễn tự động mà lời biện giải không neo được vào bằng chứng. Chính tầng suy luận ấy cũng tỏ ra giá trị nhất ở một vai trò khác với vai trò hiển nhiên: dùng như bộ định tuyến phân loại thay vì bộ tự khẳng định, hàng đợi hoãn của nó gom **95,0%** đe dọa thật vào **15,76%** khối lượng, tức làm giàu **6,03×** và cắt đi **84,24%** lượng tài liệu chuyên viên phải đọc.

Giới hạn của kiến trúc được báo cáo đầy đủ ở đúng nơi có bằng chứng cho chúng, tức Chương 4, và ba trong số đó định ra chương trình làm việc trước mắt: quy kết hiện tốt hơn khi không có tầng suy luận, tác tử chưa tự loại được một cảnh báo giả, và tầng giải thích là mất xích yếu nhất—truy xuất để lọt tài liệu không liên quan, còn chỉ **11,2%** lời biện giải dẫn ra được một giá trị log đối chiếu ngược lại bản ghi. Các hướng tương ứng là sửa tầng truy xuất từ gốc kho tri thức, hiệu chỉnh tác tử cho cả chiều loại bỏ chứ không chỉ chiều khẳng định, và một định dạng lời biện giải *buộc* phải trích dẫn chứ không chỉ cho phép trích dẫn. Hai mở rộng nhỏ hơn suy ra từ những tính chất đã nêu: neo giá trị bám ra ngoài hệ thống theo chu kỳ sẽ bịt điểm mù cắt đuôi vốn là bản chất của log-chaining, và chữ ký bất đối xứng sẽ nâng khả năng phát hiện giả mạo lên thành chống chối bỏ đúng nghĩa.

Khép lại một nỗ lực nghiên cứu nghiêm túc, nhưng mở ra những khát vọng sâu xa trong

hành trình bảo vệ không gian số bằng sức mạnh của Trí tuệ Nhân tạo Tác tử.

Tài liệu tham khảo

- [1] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, “Security Information and Event Management (SIEM): Analysis, Trends, and Usage in Critical Infrastructures,” *Sensors*, vol. 21, no. 14, art. 4759, 2021.
- [2] S. Tariq, M. Baruwat Chhetri, S. Nepal, and C. Paris, “Alert Fatigue in Security Operations Centres: Research Challenges and Opportunities,” *ACM Computing Surveys*, vol. 57, no. 9, art. 224, 2025.
- [3] Ismail, R. Kurnia, Z. A. Brata, G. A. Nelistiani, S. Heo, H. Kim, and H. Kim, “Toward Robust Security Orchestration and Automated Response in Security Operations Centers with a Hyper-Automation Approach Using Agentic Artificial Intelligence,” *Information*, vol. 16, no. 5, art. 365, 2025.
- [4] A. Vaswani *et al.*, “Attention is All You Need,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 5998–6008, 2017.
- [5] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [6] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.
- [7] OWASP GenAI Security Project, “OWASP Top 10 for Large Language Model Applications,” Version 2025, The OWASP Foundation, 2025. [Online]. Available: <https://genai.owasp.org/>
- [8] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [9] C. Torrano-Giménez, A. Pérez-Villegas, and G. Álvarez Marañón, “HTTP DATASET CSIC 2010,” Information Security Institute, Spanish National Research Council (CSIC), 2010. [Online]. Available: <https://www.isi.csic.es/dataset/HTTP>
- [10] S. Myneni, A. Chowdhary, A. Sabur, S. Sengupta, G. Agrawal, D. Huang, and M. Kang, “DAPT 2020 – Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Deployable Machine Learning for Security Defense (MLHat 2020)*, Communications in Computer and Information Science, vol. 1271, Springer, 2020, pp. 138–163.
- [11] A. Zou, Z. Wang, J. Z. Kolter, and M. Fredrikson, “Universal and Transferable Adversarial Attacks on Aligned Language Models,” *arXiv preprint arXiv:2307.15043*, 2023.
- [12] Deepset, “Prompt Injections Dataset,” *Hugging Face repository*, 2023. [Online]. Available: <https://huggingface.co/datasets/deepset/prompt-injections>
- [13] J. Hao, “Jailbreak Classification Dataset,” *Hugging Face repository*, 2023. [Online]. Available: <https://huggingface.co/datasets/jackhhao/jailbreak-classification>
- [14] R. Zuech, T. M. Khoshgoftaar, and R. Wald, “Intrusion Detection and Big Heterogeneous Data: A Survey,” *Journal of Big Data*, vol. 2, art. 3, 2015.

- [15] B. P. Welford, "Note on a Method for Calculating Corrected Sums of Squares and Products," *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [16] A. Gholami *et al.*, "A Survey of Quantization Methods for Efficient Neural Network Inference," *arXiv preprint arXiv:2103.13630*, 2021.
- [17] P. Kassinik, B. Saglam *et al.* (Cisco Foundation AI), "Llama-3.1-FoundationAI-SecurityLLM-Base-8B Technical Report," *arXiv preprint arXiv:2504.21039*, 2025.
- [18] S. Weerawardhena, P. Kassinik, B. Nelson, B. Saglam *et al.* (Cisco Foundation AI), "Llama-3.1-FoundationAI-SecurityLLM-8B-Instruct Technical Report," *arXiv preprint arXiv:2508.01059*, 2025.
- [19] LangChain AI, "LangGraph: Multi-Actor, Stateful LLM Applications," *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
- [20] P. Lewis *et al.*, "Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks," *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [21] J. Johnson, M. Douze, and H. Jégou, "Billion-Scale Similarity Search with GPUs," *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2019.
- [22] S. Robertson and H. Zaragoza, "The Probabilistic Relevance Framework: BM25 and Beyond," *Foundations and Trends in Information Retrieval*, vol. 3, no. 4, pp. 333–389, 2009.
- [23] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, "Reciprocal Rank Fusion Outperforms Condorcet and Individual Rank Learning Methods," in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009, pp. 758–759.
- [24] R. Pandey and A. Bhujang, "Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content," *arXiv preprint arXiv:2605.24421*, 2026.
- [25] H. Krawczyk, M. Bellare, and R. Canetti, "HMAC: Keyed-Hashing for Message Authentication," Internet Engineering Task Force, RFC 2104, 1997.
- [26] J. Zhang *et al.*, "When LLMs Meet Cybersecurity: A Systematic Literature Review," *Cybersecurity*, vol. 8, 2025.
- [27] B. A. AlAhmadi, L. Axon, and I. Martinovic, "99% False Positives: A Qualitative Study of SOC Analysts' Perspectives on Security Alarms," in *Proceedings of the 31st USENIX Security Symposium*, 2022, pp. 2783–2800.
- [28] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, "CyberRAG: An Agentic RAG cyber attack classification and reporting tool," *Future Generation Computer Systems*, vol. 176, art. 108186, 2026.
- [29] Z. Liu and A. Anwar, "AutoBnB-RAG: Enhancing Multi-Agent Incident Response with Retrieval-Augmented Generation," *arXiv preprint arXiv:2508.13118*, 2025.
- [30] A. Abdennebi, N. Kara, L. Lahlou, and H. Ould-Slimane, "LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations," *arXiv preprint arXiv:2604.05440*, 2026.
- [31] R. Sahay *et al.*, "Policy-Guided Threat Hunting: An LLM Enabled Framework with Splunk SOC Triage," *arXiv preprint arXiv:2603.23966*, 2026.
- [32] P. He, J. Zhu, S. He, J. Li, and M. R. Lyu, "Drain: An Online Log Parsing Approach with Fixed Depth Tree," in *Proceedings of the IEEE International Conference on Web Services (ICWS)*, 2017, pp. 33–40.
- [33] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, "MITRE ATT&CK: Design and Philosophy," The MITRE Corporation,

Technical Report MP180360, 2018.

- [34] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
- [35] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks,” in *Proceedings of the Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2019.
- [36] X. Shen, Z. Chen, M. Backes, Y. Shen, and Y. Zhang, “‘Do Anything Now’: Characterizing and Evaluating In-The-Wild Jailbreak Prompts on Large Language Models,” in *Proceedings of the 2024 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2024, pp. 1671–1685.
- [37] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
- [38] L. Zheng *et al.*, “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 36, 2023.